

INTERNACIONAL ESTÁNDAR

ISO/CEI 27002

Tercera edición
2022-02

Seguridad de la información, ciberseguridad y protección de la privacidad — Controles de seguridad de la información

*Seguridad de la información, ciberseguridad y protección de la vida
privada — Medidas de seguridad de la información*



Número de referencia
ISO/CEI 27002:2022(E)

© ISO/CEI 2022



DOCUMENTO PROTEGIDO POR DERECHOS DE AUTOR

© ISO/CEI 2022

Reservados todos los derechos. A menos que se especifique lo contrario, o se requiera en el contexto de su implementación, ninguna parte de esta publicación puede ser reproducida o utilizada de ninguna forma o por ningún medio, electrónico o mecánico, incluidas las fotocopias, o la publicación en Internet o en una intranet, sin previo aviso. permiso escrito. El permiso se puede solicitar a ISO en la dirección que se indica a continuación o al organismo miembro de ISO en el país del solicitante.

oficina de derechos de autor ISO
CP 401 • Cap. de Blandonnet 8
CH-1214 Vernier, Ginebra
Teléfono: +41 22 749 01 11 Correo
electrónico: copyright@iso.org
Sitio web: www.iso.org

Publicado en Suiza

Contenido

Página

Prefacio	vi
Introducción	viii
1 Alcance	1
2 Referencias normativas	1
3 Términos, definiciones y términos abreviados	1
3.1 Términos y definiciones	1
3.2 Términos abreviados	6
4 Estructura de este documento	7
4.1 Cláusulas	7
4.2 Temas y atributos	8
4.3 Diseño de controles	9
5 Controles organizacionales	9
5.1 Políticas de seguridad de la información	9
5.2 Roles y responsabilidades de seguridad de la información	11
5.3 Segregación de funciones	12
5.4 Responsabilidades de la dirección	13
5.5 Contacto con las autoridades	14
5.6 Contacto con grupos de interés especial	15
5.7 Inteligencia de amenazas	15
5.8 Seguridad de la información en la gestión de proyectos	17
5.9 Inventario de información y otros activos asociados	18
5.10 Uso aceptable de la información y otros activos asociados	20
5.11 Devolución de bienes	21
5.12 Clasificación de la información	22
5.13 Etiquetado de la información	23
5.14 Transferencia de información	24
5.15 Control de acceso	27
5.16 Gestión de identidad	29
5.17 Información de autenticación	30
5.18 Derechos de acceso	32
5.19 Seguridad de la información en las relaciones con los proveedores	33
5.20 Abordar la seguridad de la información en los acuerdos con proveedores	35
5.21 Gestión de la seguridad de la información en la cadena de suministro de las TIC	37
5.22 Seguimiento, revisión y gestión de cambios de servicios de proveedores	39
5.23 Seguridad de la información para el uso de servicios en la nube	41
5.24 Planificación y preparación de la gestión de incidentes de seguridad de la información	43
5.25 Evaluación y decisión sobre eventos de seguridad de la información	44
5.26 Respuesta a incidentes de seguridad de la información	45
5.27 Aprendiendo de los incidentes de seguridad de la información	46
5.28 Recopilación de pruebas	46
5.29 Seguridad de la información durante la interrupción	48
5.30 Preparación de las TIC para la continuidad del negocio	48
5.31 Requisitos legales, estatutarios, reglamentarios y contractuales	50
5.32 Derechos de propiedad intelectual	51
5.33 Protección de registros	53
5.34 Privacidad y protección de PII	54
5.35 Revisión independiente de la seguridad de la información	55
5.36 Cumplimiento de políticas, normas y estándares de seguridad de la información	56
5.37 Procedimientos operativos documentados	57
6 Controles de personas	58
6.1 Cribado	58
6.2 Términos y condiciones de empleo	59

6.3	Concientización, educación y capacitación en seguridad de la información.....	60
6.4	Proceso disciplinario.....	62
6.5	Responsabilidades después de la terminación o cambio de empleo.....	63
6.6	Acuerdos de confidencialidad o no divulgación.....	63
6.7	Trabajo a distancia.....	sesenta y cinco
6.8	Reporte de eventos de seguridad de la información.....	66
7	Controles físicos.....	67
7.1	Perímetros de seguridad física.....	67
7.2	Entrada física.....	68
7.3	Aseguramiento de oficinas, salas e instalaciones.....	70
7.4	Supervisión de la seguridad física.....	70
7.5	Protección contra amenazas físicas y ambientales.....	71
7.6	Trabajar en áreas seguras.....	72
7.7	Escritorio despejado y pantalla despejada.....	73
7.8	Ubicación y protección del equipo.....	74
7.9	Seguridad de los activos fuera de las instalaciones.....	75
7.10	Medios de almacenamiento.....	76
7.11	Utilidades de apoyo.....	77
7.12	Seguridad del cableado.....	78
7.13	Mantenimiento de equipos.....	79
7.14	Eliminación segura o reutilización de equipos.....	80
8	Controles tecnológicos.....	81
8.1	Dispositivos de punto final de usuario.....	81
8.2	Derechos de acceso privilegiado.....	83
8.3	Restricción de acceso a la información.....	84
8.4	Acceso al código fuente.....	86
8.5	Autenticación segura.....	87
8.6	Gestión de la capacidad.....	89
8.7	Protección contra malware.....	90
8.8	Gestión de vulnerabilidades técnicas.....	92
8.9	Gestión de la configuración.....	95
8.10	Eliminación de información.....	97
8.11	Enmascaramiento de datos.....	98
8.12	Prevención de fuga de datos.....	100
8.13	Copia de seguridad de la información.....	101
8.14	Redundancia de las instalaciones de procesamiento de información.....	102
8.15	Registro.....	103
8.16	Actividades de seguimiento.....	106
8.17	Sincronización del reloj.....	108
8.18	Uso de programas de utilidad privilegiados.....	109
8.19	Instalación de software en sistemas operativos.....	110
8.20	Seguridad de redes.....	111
8.21	Seguridad de los servicios de red.....	112
8.22	Segregación de redes.....	113
8.23	Filtrado web.....	114
8.24	Uso de criptografía.....	115
8.25	Ciclo de vida de desarrollo seguro.....	117
8.26	Requisitos de seguridad de la aplicación.....	118
8.27	Arquitectura del sistema seguro y principios de ingeniería.....	120
8.28	Codificación segura.....	122
8.29	Pruebas de seguridad en desarrollo y aceptación.....	124
8.30	Desarrollo subcontratado.....	126
8.31	Separación de los entornos de desarrollo, prueba y producción.....	127
8.32	Gestión de cambios.....	128
8.33	Información de prueba.....	129
8.34	Protección de los sistemas de información durante las pruebas de auditoría.....	130
	Anexo A(informativo)Usando atributos.....	132

Anexo B(informativo)Correspondencia de ISO/IEC 27002:2022 (este documento) con ISO/CEI 27002:2013.....143

Bibliografía.....150

Prefacio

ISO (Organización Internacional de Normalización) e IEC (Comisión Electrotécnica Internacional) forman el sistema especializado para la normalización mundial. Los organismos nacionales que son miembros de ISO o IEC participan en el desarrollo de Normas Internacionales a través de comités técnicos establecidos por la organización respectiva para tratar campos particulares de actividad técnica. Los comités técnicos de ISO e IEC colaboran en campos de interés mutuo. Otras organizaciones internacionales, gubernamentales y no gubernamentales, en coordinación con ISO e IEC, también participan en el trabajo.

Los procedimientos utilizados para desarrollar este documento y los destinados a su posterior mantenimiento se describen en las Directivas ISO/IEC, Parte 1. En particular, se deben tener en cuenta los diferentes criterios de aprobación necesarios para los diferentes tipos de documentos. Este documento fue redactado de acuerdo con las reglas editoriales de las Directivas ISO/IEC, Parte 2 (ver www.iso.org/directivas o www.iec.ch/members_experts/refdocs).

Se llama la atención sobre la posibilidad de que algunos de los elementos de este documento puedan ser objeto de derechos de patente. ISO e IEC no serán responsables de identificar ninguno o todos los derechos de patente. Los detalles de cualquier derecho de patente identificado durante el desarrollo del documento estarán en la Introducción y/o en la lista ISO de declaraciones de patentes recibidas (ver www.iso.org/patents) o la lista IEC de declaraciones de patentes recibidas (ver patentes.iec.ch).

Cualquier nombre comercial utilizado en este documento es información proporcionada para la comodidad de los usuarios y no constituye un respaldo.

Para obtener una explicación de la naturaleza voluntaria de las normas, el significado de los términos y expresiones específicos de ISO relacionados con la evaluación de la conformidad, así como información sobre la adhesión de ISO a los principios de la Organización Mundial del Comercio (OMC) en los obstáculos técnicos al comercio (TBT), consulte www.iso.org/iso/prefacio.html . En la CEI, véase www.iec.ch/understanding-standards .

¹Este documento fue preparado por el Comité Técnico Conjunto ISO/IEC JTC 1, *Tecnologías de la información*, Subcomité SC 27, *Seguridad de la información, ciberseguridad y protección de la privacidad*.

Esta tercera edición cancela y reemplaza la segunda edición (ISO/IEC 27002:2013), que ha sido revisada técnicamente. También incorpora la Corrección Técnica ISO/IEC 27002:2013/Cor. 1:2014 e ISO/IEC 27002:2013/Cor. 2:2015.

Los principales cambios son los siguientes:

- el título ha sido modificado;
- se ha cambiado la estructura del documento, presentando los controles utilizando una taxonomía simple y atributos asociados;
- se fusionaron algunos controles, se eliminaron algunos y se introdujeron varios controles nuevos. La correspondencia completa se encuentra en [Anexo B](#) .

Cualquier comentario o pregunta sobre este documento debe dirigirse al organismo nacional de normalización del usuario. Una lista completa de estos organismos se puede encontrar en www.iso.org/members.html y www.iec.ch/comités-nacionales .

Introducción

0.1 Antecedentes y contexto

Este documento está diseñado para organizaciones de todos los tipos y tamaños. Debe usarse como referencia para determinar e implementar controles para el tratamiento de riesgos de seguridad de la información en un sistema de gestión de seguridad de la información (SGSI) basado en ISO/IEC 27001. También puede usarse como documento de orientación para organizaciones que determinan e implementan controles de seguridad de la información. Además, este documento está diseñado para usarse en el desarrollo de pautas de gestión de seguridad de la información específicas de la industria y la organización, teniendo en cuenta sus entornos de riesgo de seguridad de la información específicos. Los controles específicos de la organización o del entorno distintos de los incluidos en este documento se pueden determinar a través de la evaluación de riesgos según sea necesario.

Las organizaciones de todos los tipos y tamaños (incluidos los sectores público y privado, comerciales y sin fines de lucro) crean, recopilan, procesan, almacenan, transmiten y eliminan información en muchas formas, incluidas las electrónicas, físicas y verbales (por ejemplo, conversaciones y presentaciones).

El valor de la información va más allá de las palabras escritas, los números y las imágenes: el conocimiento, los conceptos, las ideas y las marcas son ejemplos de formas intangibles de información. En un mundo interconectado, la información y otros activos asociados merecen o requieren protección contra diversas fuentes de riesgo, ya sean naturales, accidentales o deliberadas.

La seguridad de la información se logra mediante la implementación de un conjunto adecuado de controles, incluidas políticas, reglas, procesos, procedimientos, estructuras organizativas y funciones de software y hardware. Para cumplir con sus objetivos comerciales y de seguridad específicos, la organización debe definir, implementar, monitorear, revisar y mejorar estos controles cuando sea necesario. Un SGSI como el especificado en ISO/IEC 27001 adopta una visión holística y coordinada de los riesgos de seguridad de la información de la organización para determinar e implementar un conjunto completo de controles de seguridad de la información dentro del marco general de un sistema de gestión coherente.

Muchos sistemas de información, incluidas su gestión y operaciones, no han sido diseñados para ser seguros en términos de un SGSI como se especifica en ISO/IEC 27001 y este documento. El nivel de seguridad que solo puede lograrse mediante medidas tecnológicas es limitado y debe estar respaldado por actividades de gestión y procesos organizativos apropiados. Identificar qué controles deben implementarse requiere una planificación cuidadosa y atención a los detalles al llevar a cabo el tratamiento de riesgos.

Un SGSI exitoso requiere el apoyo de todo el personal de la organización. También puede requerir la participación de otras partes interesadas, como accionistas o proveedores. También puede ser necesario el asesoramiento de expertos en la materia.

Un sistema de gestión de la seguridad de la información adecuado, adecuado y eficaz proporciona garantías a la dirección de la organización y a otras partes interesadas de que su información y otros activos asociados se mantienen razonablemente seguros y protegidos contra amenazas y daños, lo que permite a la organización alcanzar los objetivos comerciales establecidos.

0.2 Requisitos de seguridad de la información

Es esencial que una organización determine sus requisitos de seguridad de la información. Hay tres fuentes principales de requisitos de seguridad de la información:

- a) la evaluación de los riesgos para la organización, teniendo en cuenta la estrategia y los objetivos comerciales generales de la organización. Esto se puede facilitar o respaldar a través de una evaluación de riesgos específica de la seguridad de la información. Esto debería resultar en la determinación de los controles necesarios para asegurar que el riesgo residual para la organización cumpla con sus criterios de aceptación del riesgo;
- b) los requisitos legales, estatutarios, reglamentarios y contractuales que debe cumplir una organización y sus partes interesadas (socios comerciales, proveedores de servicios, etc.) y su entorno sociocultural;

c) el conjunto de principios, objetivos y requisitos comerciales para todos los pasos del ciclo de vida de la información que una organización ha desarrollado para respaldar sus operaciones.

0.3 Controles

Un control se define como una medida que modifica o mantiene el riesgo. Algunos de los controles en este documento son controles que modifican el riesgo, mientras que otros mantienen el riesgo. Una política de seguridad de la información, por ejemplo, solo puede mantener el riesgo, mientras que el cumplimiento de la política de seguridad de la información puede modificar el riesgo. Además, algunos controles describen la misma medida genérica en diferentes contextos de riesgo. Este documento proporciona una combinación genérica de controles de seguridad de la información organizacionales, de personas, físicos y tecnológicos derivados de las mejores prácticas reconocidas internacionalmente.

0.4 Determinación de controles

La determinación de los controles depende de las decisiones de la organización luego de una evaluación de riesgos, con un alcance claramente definido. Las decisiones relacionadas con los riesgos identificados deben basarse en los criterios de aceptación del riesgo, las opciones de tratamiento del riesgo y el enfoque de gestión del riesgo aplicado por la organización. La determinación de los controles también debe tener en cuenta todas las leyes y reglamentos nacionales e internacionales pertinentes. La determinación del control también depende de la forma en que los controles interactúan entre sí para brindar una defensa en profundidad.

La organización puede diseñar controles según sea necesario o identificarlos de cualquier fuente. Al especificar dichos controles, la organización debe considerar los recursos y la inversión necesarios para implementar y operar un control contra el valor comercial obtenido. Consulte ISO/IEC TR 27016 para obtener orientación sobre las decisiones relacionadas con la inversión en un SGSI y las consecuencias económicas de estas decisiones en el contexto de los requisitos competitivos de recursos.

Debe haber un equilibrio entre los recursos desplegados para implementar los controles y el posible impacto comercial resultante de los incidentes de seguridad en ausencia de esos controles. Los resultados de una evaluación de riesgos deben ayudar a guiar y determinar la acción de gestión apropiada, las prioridades para gestionar los riesgos de seguridad de la información y para implementar los controles que se determinen necesarios para proteger contra estos riesgos.

Algunos de los controles de este documento pueden considerarse como principios rectores para la gestión de la seguridad de la información y aplicables a la mayoría de las organizaciones. Se puede encontrar más información sobre la determinación de controles y otras opciones de tratamiento de riesgos en ISO/IEC 27005.

0.5 Elaboración de directrices específicas para la organización

Este documento puede considerarse como un punto de partida para el desarrollo de directrices específicas de la organización. No todos los controles y la orientación de este documento pueden aplicarse a todas las organizaciones. También se pueden requerir controles y pautas adicionales no incluidos en este documento para abordar las necesidades específicas de la organización y los riesgos que se han identificado. Cuando se desarrollan documentos que contienen pautas o controles adicionales, puede ser útil incluir referencias cruzadas a las cláusulas de este documento para referencia futura.

0.6 Consideraciones sobre el ciclo de vida

La información tiene un ciclo de vida, desde su creación hasta su eliminación. El valor y los riesgos de la información pueden variar a lo largo de este ciclo de vida (p. ej., la divulgación no autorizada o el robo de las cuentas financieras de una empresa no son significativos una vez que se han publicado, pero la integridad sigue siendo crítica); por lo tanto, la seguridad de la información sigue siendo importante hasta cierto punto en todas las etapas.

Los sistemas de información y otros activos relevantes para la seguridad de la información tienen ciclos de vida dentro de los cuales se conciben, especifican, diseñan, desarrollan, prueban, implementan, usan, mantienen y finalmente se retiran del servicio y se desechan. La seguridad de la información debe ser considerada en cada etapa. Los proyectos de desarrollo de nuevos sistemas y los cambios en los sistemas existentes brindan oportunidades para mejorar los controles de seguridad mientras se tienen en cuenta los riesgos de la organización y las lecciones aprendidas de los incidentes.

0.7 Normas internacionales relacionadas

Si bien este documento ofrece orientación sobre una amplia gama de controles de seguridad de la información que se aplican comúnmente en muchas organizaciones diferentes, otros documentos de la familia ISO/IEC 27000 brindan consejos o requisitos complementarios sobre otros aspectos del proceso general de gestión de la seguridad de la información.

Consulte ISO/IEC 27000 para obtener una introducción general tanto al SGSI como a la familia de documentos. ISO/IEC 27000 proporciona un glosario que define la mayoría de los términos utilizados en toda la familia de documentos ISO/IEC 27000 y describe el alcance y los objetivos de cada miembro de la familia.

Existen estándares específicos del sector que tienen controles adicionales que apuntan a abordar áreas específicas (p. ej., ISO/IEC 27017 para servicios en la nube, ISO/IEC 27701 para privacidad, ISO/IEC 27019 para energía, ISO/IEC 27011 para organizaciones de telecomunicaciones e ISO 27799 por salud). Dichos estándares se incluyen en la Bibliografía y algunos de ellos se mencionan en las secciones de orientación y otra información en [Cláusulas 5 -8](#).

Seguridad de la información, ciberseguridad y protección de la privacidad — Controles de seguridad de la información

1 Alcance

Este documento proporciona un conjunto de referencia de controles genéricos de seguridad de la información, incluida una guía de implementación. Este documento está diseñado para ser utilizado por organizaciones:

- a) dentro del contexto de un sistema de gestión de seguridad de la información (SGSI) basado en ISO/IEC 27001;
- b) para implementar controles de seguridad de la información basados en las mejores prácticas reconocidas internacionalmente;
- c) para desarrollar directrices de gestión de la seguridad de la información específicas de la organización.

2 Referencias normativas

No hay referencias normativas en este documento.

3 Términos, definiciones y términos abreviados

3.1 Términos y definiciones

A los efectos de este documento, se aplican los siguientes términos y definiciones.

ISO e IEC mantienen bases de datos de terminología para su uso en la normalización en las siguientes direcciones:

- Plataforma de navegación ISO Online: disponible en <https://www.iso.org/obp>
- Electropedia IEC: disponible en <https://www.electropedia.org/>

3.1.1

control de acceso

medios para asegurar que el acceso físico y lógico a *activos* (3.1.2) está autorizado y restringido en función de los requisitos comerciales y de seguridad de la información

3.1.2

activo

cualquier cosa que tenga valor para la organización

Nota 1 a la entrada: En el contexto de la seguridad de la información, se pueden distinguir dos tipos de activos:

- los activos primarios:
 - información;
 - negocio *procesos* (3.1.27) y actividades;
- los activos de apoyo (de los que dependen los activos primarios) de todo tipo, por ejemplo:
 - ferretería;
 - software;
 - red;
 - *personal* (3.1.20);

- sitio;

— la estructura de la organización.

3.1.3

ataque

intento no autorizado exitoso o fallido de destruir, alterar, deshabilitar, obtener acceso a un *activo* (3.1.2) o cualquier intento de exponer, robar o hacer uso no autorizado de un *activo* (3.1.2)

3.1.4

autenticación

garantía de que una característica reivindicada de un *entidad* (3.1.11) es correcto

3.1.5

autenticidad

propiedad que un *entidad* (3.1.11) es lo que dice ser

3.1.6

cadena de custodia

posesión demostrable, movimiento, manejo y ubicación de material de un punto en el tiempo a otro

Nota 1 a la entrada: El material incluye información y otros datos asociados. *activos* (3.1.2) en el contexto de ISO/IEC 27002.

[ORIGEN: ISO/IEC 27050-1:2019, 3.1, modificado — “Nota 1 a la entrada” añadida]

3.1.7

información confidencial

información que no está destinada a estar disponible o divulgada a personas no autorizadas, *entidades* (3.1.11) o *procesos* (3.1.27)

3.1.8

control

medida que mantiene y/o modifica el riesgo

Nota 1 a la entrada: Los controles incluyen, entre otros, cualquier *proceso* (3.1.27), *política* (3.1.24), dispositivo, práctica u otras condiciones y/o acciones que mantienen y/o modifican el riesgo.

Nota 2 a la entrada: Es posible que los controles no siempre ejerzan el efecto de modificación pretendido o asumido.

[FUENTE: ISO 31000:2018, 3.8]

3.1.9

ruptura

incidente, ya sea anticipado o no, que causa una desviación negativa no planificada de la entrega esperada de productos y servicios de acuerdo con los objetivos de una organización

[FUENTE: ISO 22301:2019, 3.10]

3.1.10

dispositivo de punto final

dispositivo de hardware de tecnología de la información y la comunicación (TIC) conectado a la red

Nota 1 a la entrada: Dispositivo de punto final puede referirse a computadoras de escritorio, portátiles, teléfonos inteligentes, tabletas, clientes ligeros, impresoras u otro hardware especializado, incluidos medidores inteligentes y dispositivos de Internet de las cosas (IoT).

3.1.11

entidad

elemento relevante para el propósito de la operación de un dominio que tiene una existencia reconociblemente distinta

Nota 1 a la entrada: Una entidad puede tener una realización física o lógica.

EJEMPLO Una persona, una organización, un dispositivo, un grupo de tales elementos, un suscriptor humano de una empresa de telecomunicaciones, servicio, una tarjeta SIM, un pasaporte, una tarjeta de interfaz de red, una aplicación de software, un servicio o un sitio web.

[FUENTE: ISO/IEC 24760-1:2019, 3.1.1]

3.1.12

instalación de procesamiento de información

cualquier sistema, servicio o infraestructura de procesamiento de información, o la ubicación física que lo alberga

[ORIGEN: ISO/IEC 27000:2018, 3.27, modificado — "facilities" se reemplazó por facilidad.]

3.1.13

violación de la seguridad de la información

compromiso de la seguridad de la información que conduce a la destrucción, pérdida, alteración, divulgación o acceso no deseados a la información protegida transmitida, almacenada o procesada de otro modo

3.1.14

evento de seguridad de la información

ocurrencia que indica una posible *violación de la seguridad de la información* ([3.1.13](#)) o fallo de *control* ([3.1.8](#))

[ORIGEN: ISO/IEC 27035-1:2016, 3.3, modificado: "violación de la seguridad de la información" se ha reemplazado por "violación de la seguridad de la información"]

3.1.15

incidente de seguridad de la información

uno o varios relacionados e identificados *eventos de seguridad de la información* ([3.1.14](#)) que pueden dañar la organización *activos* ([3.1.2](#)) o comprometer sus operaciones

[FUENTE: ISO/IEC 27035-1:2016, 3.4]

3.1.16

gestión de incidentes de seguridad de la información

ejercicio de un enfoque consistente y efectivo para el manejo de *incidentes de seguridad de la información* ([3.1.15](#))

[FUENTE: ISO/IEC 27035-1:2016, 3.5]

3.1.17

sistema de información

conjunto de aplicaciones, servicios, tecnología de la información *activos* ([3.1.2](#)), u otros componentes de manejo de información

[FUENTE: ISO/IEC 27000:2018, 3.35]

3.1.18

parte interesada

Interesado

persona u organización que puede afectar, ser afectada o percibirse a sí misma como afectada por una decisión o actividad

[FUENTE: ISO/IEC 27000:2018, 3.37]

3.1.19

no repudio

capacidad de probar la ocurrencia de un evento o acción reclamada y su origen *entidades* ([3.1.11](#))

3.1.20

personal

personas que trabajan bajo la dirección de la organización

Nota 1 a la entrada: El concepto de personal incluye a los miembros de la organización, tales como el órgano de gobierno, la alta dirección, los empleados, el personal temporal, los contratistas y los voluntarios.

3.1.21

información de identificación personal

PII

cualquier información que (a) pueda utilizarse para establecer un vínculo entre la información y la persona física a la que se refiere dicha información, o (b) esté o pueda estar vinculada directa o indirectamente a una persona física.

Nota 1 a la entrada: La "persona física" en la definición es la *director de información personal identificable* (3.1.22). Para determinar si un principal de PII es identificable, se deben tener en cuenta todos los medios que razonablemente puede utilizar la parte interesada en la privacidad que posee los datos, o cualquier otra parte, para establecer el vínculo entre el conjunto de PII y la persona física.

[FUENTE: ISO/IEC 29100:2011/Amd.1:2018, 2.9]

3.1.22

director de información personal identificable

persona natural a quien el *información de identificación personal* (PII) (3.1.21) se relaciona

Nota 1 a la entrada: Dependiendo de la jurisdicción y de la legislación particular de privacidad y protección de datos, también se puede usar el sinónimo "sujeto de datos" en lugar del término "principal de PII".

[FUENTE: ISO/IEC 29100:2011, 2.11]

3.1.23

procesador de información personal

parte interesada en privacidad que procesa *información de identificación personal* (PII) (3.1.21) en nombre y de acuerdo con las instrucciones de un controlador de PII

[FUENTE: ISO/IEC 29100:2011, 2.12]

3.1.24

política

Intenciones y dirección de una organización, expresadas formalmente por su alta dirección.

[FUENTE: ISO/IEC 27000:2018, 3.53]

3.1.25

evaluación de impacto en la privacidad

PIA

en general *proceso* (3.1.27) de identificar, analizar, evaluar, consultar, comunicar y planificar el tratamiento de los posibles impactos sobre la privacidad en relación con el tratamiento de *información de identificación personal* (PII) (3.1.21), enmarcado dentro del marco más amplio de gestión de riesgos de una organización

[FUENTE: ISO/IEC 29134:2017, 3.7, modificado — Nota 1 a la entrada eliminada.]

3.1.26

procedimiento

forma específica de llevar a cabo una actividad o un *proceso* (3.1.27)

[FUENTE: ISO 30000:2009, 3.12]

3.1.27

proceso

conjunto de actividades interrelacionadas o que interactúan que usa o transforma entradas para entregar un resultado

[FUENTE: ISO 9000:2015, 3.4.1, modificada — Notas a la entrada eliminadas.]

3.1.28

registro

información creada, recibida y mantenida como evidencia y como *activo* (3.1.2) por una organización o persona, en cumplimiento de obligaciones legales o en la transacción de negocios

Nota 1 a la entrada: Las obligaciones legales en este contexto incluyen todos los requisitos legales, estatutarios, reglamentarios y contractuales.

[ORIGEN: ISO 15489-1:2016, 3.14, modificado—"Nota 1 a la entrada" agregada.]

3.1.29

punto de recuperación objetivo

RPO

punto en el tiempo en el que se van a recuperar los datos después de una *ruptura* (3.1.9) ha ocurrido

[FUENTE: ISO/IEC 27031:2011, 3.12, modificado - "debe" reemplazado por "debe ser".]

3.1.30

tiempo de recuperación objetivo

RTO

período de tiempo dentro del cual se recuperarán los niveles mínimos de servicios y/o productos y los sistemas, aplicaciones o funciones de soporte después de una *ruptura* (3.1.9) ha ocurrido

[FUENTE: ISO/IEC 27031:2011, 3.13, modificado - "debe" reemplazado por "debe ser".]

3.1.31

fiabilidad

propiedad de comportamiento y resultados consistentes previstos

3.1.32

regla

principio aceptado o instrucción que establece las expectativas de la organización sobre lo que se requiere hacer, lo que está permitido o no permitido

Nota 1 a la entrada: Las reglas pueden expresarse formalmente en *políticas de temas específicos* (3.1.35) y en otro tipo de documentos.

3.1.33

información sensible

información que debe protegerse contra la falta de disponibilidad, el acceso no autorizado, la modificación o la divulgación pública debido a posibles efectos adversos en un individuo, organización, seguridad nacional o seguridad pública

3.1.34

amenaza

causa potencial de un incidente no deseado, que puede resultar en daño a un sistema u organización

[FUENTE: ISO/IEC 27000:2018, 3.74]

3.1.35

política específica del tema

Intenciones y dirección sobre un tema o tema específico, según lo expresado formalmente por el nivel apropiado de gestión.

Nota 1 a la entrada: Las políticas específicas de un tema pueden expresar formalmente *normas* (3.1.32) o normas de la organización.

Nota 2 a la entrada: Algunas organizaciones usan otros términos para estas políticas de temas específicos.

Nota 3 a la entrada: Las políticas específicas del tema a las que se hace referencia en este documento están relacionadas con la seguridad de la información.

EJEMPLO Política específica de un tema sobre *control de acceso* (3.1.1), política específica del tema sobre escritorio despejado y pantalla despejada.

3.1.36

usuario

parte interesada (3.1.18) con acceso a la organización *sistemas de información* (3.1.17)

EJEMPLO *Persona* (3.1.20), clientes, proveedores.

3.1.37

dispositivo de punto final del usuario

dispositivo de punto final(3.1.10) utilizados por los usuarios para acceder a los servicios de procesamiento de información

Nota 1 a la entrada: El dispositivo de punto final del usuario puede referirse a computadoras de escritorio, portátiles, teléfonos inteligentes, tabletas, clientes ligeros, etc.

3.1.38

vulnerabilidad

debilidad de un activo(3.1.2) o control(3.1.8) que pueden ser explotados por uno o más amenazas(3.1.34)

[FUENTE: ISO/IEC 27000:2018, 3.77]

3.2 Términos abreviados

ABAC control de acceso basado en atributos

LCA lista de control de acceso

BIA Análisis de Impacto del Negocio

BYOD trae tu propio dispositivo

CAPTCHA Prueba de Turing pública completamente automatizada para diferenciar a las computadoras de los humanos

UPC unidad Central de procesamiento

CAD control de acceso discrecional

DNS sistema de nombres de dominio

GPS sistema de Posicionamiento Global

SOY gestión de identidad y acceso

TIC tecnología de la información y la comunicación

IDENTIFICACIÓN identificador

IDE entorno de desarrollo integrado

DNI sistema de detección de intrusos

internet de las cosas Internet de las Cosas

IP protocolo de Internet

IPS Sistema de Prevención de Intrusión

ÉL tecnologías de la información

SGSI sistema de gestión de seguridad de la información

MAC control de acceso obligatorio

NTP Protocolo de tiempo de red

PIA evaluación del impacto en la privacidad

información personal información de identificación personal

ALFILER	número de identificación personal
PKI	Infraestructura de Clave Pública
PTP	protocolo de tiempo de precisión
RBAC	control de acceso basado en roles
RPO	objetivo de punto de recuperación
RTO	objetivo de tiempo de recuperación
SAST	pruebas de seguridad de aplicaciones estáticas
Dakota del Sur	Seguro digital
SDN	Redes definidas por software
SD-WAN	redes de área amplia definidas por software
SIEM	información de seguridad y gestión de eventos
SMS	servicio de mensajes cortos
sql	lenguaje de consulta estructurado
inicio de sesión único	inicio de sesión único
SWID	identificación de software
UEBA	análisis de comportamiento de usuarios y entidades
UPS	fuentes de poder ininterrumpible
URL	Localizador Uniforme de Recursos
USB	bus serie universal
máquina virtual	máquina virtual
vpn	red privada virtual
Wifi	fidelidad inalámbrica

4 Estructura de este documento

4.1 Cláusulas

Este documento está estructurado de la siguiente manera:

- a) Controles organizacionales ([Cláusula 5](#))
- b) Controles de personas ([Cláusula 6](#))
- c) Controles físicos ([Cláusula 7](#))
- d) Controles tecnológicos ([Cláusula 8](#))

Hay 2 anexos informativos:

— [Anexo A](#) — Uso de atributos

— [Anexo B](#) — Correspondencia con ISO/IEC 27002:2013

[Anexo A](#) explica cómo una organización puede usar atributos (ver [4.2](#)) para crear sus propias vistas basadas en los atributos de control definidos en este documento o de creación propia.

[Anexo B](#) muestra la correspondencia entre los controles en esta edición de ISO/IEC 27002 y la edición anterior de 2013.

4.2 Temas y atributos

La categorización de los controles dada en [Cláusulas 5 a 8](#) se denominan temas.

Los controles se clasifican como:

- a) personas, si se refieren a personas individuales;
- b) físicos, si se trata de objetos físicos;
- c) tecnológicos, si se trata de tecnología;
- d) en caso contrario se categorizan como organizacionales.

La organización puede usar atributos para crear diferentes vistas que son diferentes categorizaciones de controles vistos desde una perspectiva diferente a los temas. Los atributos se pueden usar para filtrar, ordenar o presentar controles en diferentes vistas para diferentes audiencias. [Anexo A](#) explica cómo se puede lograr esto y proporciona un ejemplo de una vista.

A modo de ejemplo, cada control en este documento se ha asociado con cinco atributos con los valores de atributos correspondientes (precedidos por "#" para que se puedan buscar), de la siguiente manera:

a) Tipo de control

El tipo de control es un atributo para ver los controles desde la perspectiva de cuándo y cómo el control modifica el riesgo con respecto a la ocurrencia de un incidente de seguridad de la información. Los valores de los atributos consisten en Preventivo (el control que pretende prevenir la ocurrencia de un incidente de seguridad de la información), Detectivo (el control actúa cuando ocurre un incidente de seguridad de la información) y Correctivo (el control actúa después de que ocurre un incidente de seguridad de la información).

b) Propiedades de seguridad de la información

Las propiedades de seguridad de la información son un atributo para ver los controles desde la perspectiva de qué característica de la información contribuirá a preservar el control. Los valores de atributo consisten en Confidencialidad, Integridad y Disponibilidad.

c) Conceptos de ciberseguridad

Los conceptos de ciberseguridad son un atributo para ver los controles desde la perspectiva de la asociación de controles a los conceptos de ciberseguridad definidos en el marco de ciberseguridad descrito en ISO/IEC TS 27110. Los valores de atributo consisten en Identificar, Proteger, Detectar, Responder y Recuperar.

d) Capacidades operativas

Las capacidades operativas son un atributo para ver los controles desde la perspectiva del profesional de las capacidades de seguridad de la información. Los valores de los atributos consisten en Gobernanza, Gestión_de_activos, Protección_de_la_información, Seguridad_de_recursos_humanos, Seguridad_física, Seguridad_de_sistemas_y_redes, Seguridad_de_aplicaciones, Configuración_segura, Gestión_de_identidades_y_accesos, Gestión_de_amenazas_y_vulnerabilidades, Continuidad, Seguridad_de_relaciones_con_proveedores, Legal_y_cumplimiento, Gestión_de_eventos_de_seguridad_de_información y Garantía_de_seguridad_de_información.

e) Dominios de seguridad

Los dominios de seguridad son un atributo para ver los controles desde la perspectiva de cuatro dominios de seguridad de la información: "Gobierno y ecosistema" incluye "Gobierno de seguridad del sistema de información y gestión de riesgos" y "Gestión de ciberseguridad del ecosistema" (incluidas las partes interesadas internas y externas); "Protección" incluye "Arquitectura de seguridad de TI", "Administración de seguridad de TI", "Gestión de acceso e identidad", "Mantenimiento de seguridad de TI" y "Seguridad física y ambiental"; "Defensa" incluye "Detección" y "Gestión de incidentes de seguridad informática"; "Resiliencia" incluye "Continuidad de operaciones" y "Gestión de crisis". Los valores de atributo consisten en Gobernanza_y_Ecosistema, Protección, Defensa y Resiliencia.

Los atributos proporcionados en este documento se seleccionan porque se consideran lo suficientemente genéricos para ser utilizados por diferentes tipos de organizaciones. Las organizaciones pueden optar por ignorar uno o más de los atributos proporcionados en este documento. También pueden crear sus propios atributos (con los valores de atributos correspondientes) para crear sus propias vistas organizativas. [Cláusula A.2](#) incluye ejemplos de tales atributos.

4.3 Diseño de controles

El diseño de cada control contiene lo siguiente:

- **Título de control:** Nombre corto del control;
- **Tabla de atributos:** Una tabla muestra los valores de cada atributo para el control dado;
- **Control:**Cuál es el control;
- **Objetivo:** Por qué se debe implementar el control;
- **Guía:**Cómo se debe implementar el control;
- **Otra información:**Texto explicativo o referencias a otros documentos relacionados.

Los subtítulos se utilizan en el texto de guía para algunos controles para facilitar la lectura cuando la guía es larga y aborda varios temas. Dichos encabezados no se utilizan necesariamente en todos los textos de orientación. Los subtítulos son subrayada.

5 Controles organizacionales

5.1 Políticas de seguridad de la información

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Identificar	# Gobernanza	# Gobernanza_y_Eco- sistema #Resiliencia

Control

La política de seguridad de la información y las políticas específicas del tema deben ser definidas, aprobadas por la gerencia, publicadas, comunicadas y reconocidas por el personal relevante y las partes interesadas relevantes, y revisadas a intervalos planificados y si ocurren cambios significativos.

Objetivo

Garantizar la idoneidad, la adecuación y la eficacia continuas de la dirección de gestión y el apoyo a la seguridad de la información de acuerdo con los requisitos comerciales, legales, estatutarios, reglamentarios y contractuales.

Guía

Al más alto nivel, la organización debería definir una “política de seguridad de la información” que sea aprobada por la alta dirección y que establezca el enfoque de la organización para gestionar su seguridad de la información.

La política de seguridad de la información debe tomar en consideración los requisitos derivados de:

- a) estrategia comercial y requisitos;
- b) reglamentos, legislación y contratos;
- c) los riesgos y amenazas actuales y proyectados para la seguridad de la información.

La política de seguridad de la información debe contener declaraciones relativas a:

- a) definición de seguridad de la información;
- b) objetivos de seguridad de la información o el marco para establecer objetivos de seguridad de la información;
- c) principios para guiar todas las actividades relacionadas con la seguridad de la información;
- d) compromiso de satisfacer los requisitos aplicables relacionados con la seguridad de la información;
- e) compromiso con la mejora continua del sistema de gestión de seguridad de la información;
- f) asignación de responsabilidades para la gestión de la seguridad de la información a roles definidos;
- g) procedimientos para el manejo de exenciones y excepciones.

La alta dirección debe aprobar cualquier cambio en la política de seguridad de la información.

En un nivel más bajo, la política de seguridad de la información debe estar respaldada por políticas específicas del tema según sea necesario, para exigir aún más la implementación de controles de seguridad de la información. Las políticas de temas específicos generalmente se estructuran para abordar las necesidades de ciertos grupos objetivo dentro de una organización o para cubrir ciertas áreas de seguridad. Las políticas específicas de un tema deben estar alineadas y complementarse con la política de seguridad de la información de la organización.

Ejemplos de tales temas incluyen:

- a) control de acceso;
- b) seguridad física y ambiental;
- c) gestión de activos;
- d) transferencia de información;
- e) configuración y manejo seguros de los dispositivos de punto final del usuario;
- f) seguridad de redes;
- g) gestión de incidentes de seguridad de la información;
- h) copia de seguridad;
- i) criptografía y gestión de claves;
- j) clasificación y manejo de la información;
- k) gestión de vulnerabilidades técnicas;
- l) desarrollo seguro.

La responsabilidad del desarrollo, revisión y aprobación de las políticas específicas del tema debe asignarse al personal pertinente en función de su nivel apropiado de autoridad y competencia técnica. La revisión debe incluir la evaluación de las oportunidades de mejora de la política de seguridad de la información de la organización y las políticas específicas del tema y la gestión de la seguridad de la información en respuesta a los cambios en:

- a) la estrategia comercial de la organización;
- b) el entorno técnico de la organización;
- c) reglamentos, estatutos, legislación y contratos;
- d) riesgos de seguridad de la información;
- e) el entorno actual y proyectado de amenazas a la seguridad de la información;
- f) lecciones aprendidas de eventos e incidentes de seguridad de la información.

La revisión de la política de seguridad de la información y las políticas específicas del tema deben tener en cuenta los resultados de las revisiones y auditorías de gestión. Se debe considerar la revisión y actualización de otras políticas relacionadas cuando se cambia una política para mantener la coherencia.

La política de seguridad de la información y las políticas específicas del tema deben comunicarse al personal relevante y a las partes interesadas en una forma que sea relevante, accesible y comprensible para el lector previsto. Se debe exigir a los destinatarios de las políticas que reconozcan que comprenden y aceptan cumplir con las políticas cuando corresponda. La organización puede determinar los formatos y nombres de estos documentos de política que satisfagan las necesidades de la organización. En algunas organizaciones, la política de seguridad de la información y las políticas específicas del tema pueden estar en un solo documento. La organización puede denominar a estas políticas temáticas como estándares, directivas, políticas u otros.

Si la política de seguridad de la información o cualquier política específica de un tema se distribuye fuera de la organización, se debe tener cuidado de no revelar información confidencial de manera inapropiada.

[tabla 1](#) ilustra las diferencias entre la política de seguridad de la información y la política específica de un tema.

Tabla 1: Diferencias entre la política de seguridad de la información y la política específica del tema

	política de seguridad de la información	Política de temas específicos
Nivel de detalle	General o de alto nivel	Específico y detallado
Documentado y aprobado formalmente por	alta dirección	Nivel adecuado de gestión

Otra información

Las políticas específicas de un tema pueden variar entre organizaciones.

5.2 Roles y responsabilidades de seguridad de la información

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Identificar	# Gobernanza	# Gobernanza_y_Ecosistema #Protección #Resiliencia

Control

Los roles y responsabilidades de seguridad de la información deben definirse y asignarse de acuerdo con las necesidades de la organización.

Objetivo

Establecer una estructura definida, aprobada y entendida para la implementación, operación y gestión de la seguridad de la información dentro de la organización.

Guía

La asignación de roles y responsabilidades de seguridad de la información debe realizarse de acuerdo con la política de seguridad de la información y las políticas específicas del tema (ver [5.1](#)). La organización debería definir y gestionar las responsabilidades para:

- a) protección de la información y otros activos asociados;
- b) realizar procesos específicos de seguridad de la información;
- c) actividades de gestión de riesgos de seguridad de la información y, en particular, aceptación de riesgos residuales (por ejemplo, para los propietarios de riesgos);
- d) todo el personal que utiliza la información de una organización y otros activos asociados.

Estas responsabilidades deben complementarse, cuando sea necesario, con una guía más detallada para sitios específicos e instalaciones de procesamiento de información. Las personas con responsabilidades de seguridad de la información asignadas pueden asignar tareas de seguridad a otros. Sin embargo, siguen siendo responsables y deben determinar que las tareas delegadas se hayan realizado correctamente.

Cada área de seguridad de la cual los individuos son responsables debe definirse, documentarse y comunicarse. Los niveles de autorización deben definirse y documentarse. Las personas que asumen una función específica de seguridad de la información deben ser competentes en el conocimiento y las habilidades requeridas por la función y deben recibir apoyo para mantenerse al día con los desarrollos relacionados con la función y necesarios para cumplir con las responsabilidades de la función.

Otra información

Muchas organizaciones designan a un gerente de seguridad de la información para que asuma la responsabilidad general del desarrollo y la implementación de la seguridad de la información y para respaldar la identificación de riesgos y los controles de mitigación.

Sin embargo, la responsabilidad de dotar de recursos e implementar los controles a menudo recae en los gerentes individuales. Una práctica común es designar un propietario para cada activo, quien luego se hace responsable de su protección diaria.

Según el tamaño y los recursos de una organización, la seguridad de la información puede estar cubierta por funciones o funciones dedicadas que se llevan a cabo además de las funciones existentes.

5.3 Segregación de funciones

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# Gobernanza # identidad_y_ac- cess_management	# Gobernanza_y_Ecosistema

Control

Deben segregarse los deberes conflictivos y las áreas conflictivas de responsabilidad.

Objetivo

Reducir el riesgo de fraude, error y elusión de los controles de seguridad de la información.

Guía

La segregación de deberes y áreas de responsabilidad tiene como objetivo separar los deberes en conflicto entre diferentes individuos para evitar que un individuo ejecute deberes potencialmente conflictivos por su cuenta.

La organización debe determinar qué deberes y áreas de responsabilidad deben segregarse. Los siguientes son ejemplos de actividades que pueden requerir segregación:

- a) iniciar, aprobar y ejecutar un cambio;
- b) solicitar, aprobar e implementar derechos de acceso;
- c) diseñar, implementar y revisar el código;
- d) desarrollar software y administrar sistemas de producción;
- e) usar y administrar aplicaciones;
- f) utilizar aplicaciones y administrar bases de datos;
- g) diseñar, auditar y asegurar los controles de seguridad de la información.

Se debe considerar la posibilidad de colusión al diseñar los controles de segregación. Las organizaciones pequeñas pueden encontrar difícil lograr la segregación de funciones, pero el principio debe aplicarse en la medida de lo posible y practicable. Siempre que sea difícil segregar, se deben considerar otros controles, como el seguimiento de las actividades, las pistas de auditoría y la supervisión de la gestión.

Se debe tener cuidado al utilizar sistemas de control de acceso basados en roles para garantizar que a las personas no se les otorguen roles en conflicto. Cuando hay una gran cantidad de roles, la organización debe considerar el uso de herramientas automatizadas para identificar conflictos y facilitar su eliminación. Los roles deben definirse y aprovisionarse cuidadosamente para minimizar los problemas de acceso si se elimina o reasigna un rol.

Otra información

Ninguna otra información.

5.4 Responsabilidades de la dirección

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Identificar	# Gobernanza	# Gobernanza_y_Ecosistema

Control

La gerencia debe exigir a todo el personal que aplique la seguridad de la información de acuerdo con la política de seguridad de la información establecida, las políticas y los procedimientos específicos del tema de la organización.

Objetivo

Asegurar que la gerencia comprenda su papel en la seguridad de la información y emprender acciones destinadas a garantizar que todo el personal conozca y cumpla con sus responsabilidades de seguridad de la información.

Guía

La gerencia debe demostrar su apoyo a la política de seguridad de la información, las políticas, los procedimientos y los controles de seguridad de la información específicos de cada tema.

Las responsabilidades de la gerencia deben incluir asegurar que el personal:

- a) estén debidamente informados sobre sus roles y responsabilidades de seguridad de la información antes de que se les conceda acceso a la información de la organización y otros activos asociados;

- b) cuentan con lineamientos que establecen las expectativas de seguridad de la información de su rol dentro de la organización;
- c) tienen el mandato de cumplir con la política de seguridad de la información y las políticas específicas de la organización;
- d) lograr un nivel de conciencia de la seguridad de la información relevante para sus roles y responsabilidades dentro de la organización (ver6.3);
- e) el cumplimiento de los términos y condiciones de empleo, contrato o acuerdo, incluida la política de seguridad de la información de la organización y los métodos de trabajo apropiados;
- f) continuar teniendo las habilidades y calificaciones apropiadas en seguridad de la información a través de la educación profesional continua;
- g) cuando sea factible, cuenten con un canal confidencial para denunciar violaciones de la política de seguridad de la información, políticas específicas de un tema o procedimientos para la seguridad de la información ("denuncia"). Esto puede permitir informes anónimos o tener disposiciones para garantizar que el conocimiento de la identidad del denunciante sea conocido solo por aquellos que necesitan tratar con dichos informes;
- h) cuentan con recursos adecuados y tiempo de planificación de proyectos para implementar los procesos y controles relacionados con la seguridad de la organización.

Otra información

Ninguna otra información.

5.5 Contacto con las autoridades

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo # Correctivo	# Confidencialidad # Integridad # Disponibilidad	# Identificar # Proteger # Responder #Recuperar	# Gobernanza	# Defensa # Resiliencia

Control

La organización debe establecer y mantener contacto con las autoridades pertinentes.

Objetivo

Garantizar que se produzca un flujo de información adecuado con respecto a la seguridad de la información entre la organización y las autoridades legales, reguladoras y de supervisión pertinentes.

Guía

La organización debe especificar cuándo y quién debe contactar a las autoridades (p. ej., fuerzas del orden, organismos reguladores, autoridades de supervisión) y cómo deben informarse oportunamente los incidentes de seguridad de la información identificados.

Los contactos con las autoridades también deben utilizarse para facilitar la comprensión de las expectativas actuales y futuras de estas autoridades (por ejemplo, las normas de seguridad de la información aplicables).

Otra información

Las organizaciones bajo ataque pueden solicitar a las autoridades que tomen medidas contra la fuente del ataque.

Mantener dichos contactos puede ser un requisito para respaldar la gestión de incidentes de seguridad de la información (ver5.24 a5.28) o los procesos de planificación de contingencia y continuidad del negocio (ver5.29 y5.30). Los contactos con los organismos reguladores también son útiles para anticipar y prepararse para los próximos cambios en las leyes o reglamentos relevantes que afectan a la organización. Los contactos con otras autoridades incluyen servicios públicos, servicios de emergencia, proveedores de electricidad y salud y seguridad [por ejemplo, departamentos de bomberos (en

conexión con la continuidad del negocio), proveedores de telecomunicaciones (en relación con el enrutamiento y la disponibilidad de la línea) y proveedores de agua (en relación con las instalaciones de refrigeración para equipos)].

5.6 Contacto con grupos de interés especial

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo # Correctivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger #Responder # Recuperar	# Gobernanza	# Defensa

Control

La organización debe establecer y mantener contacto con grupos de interés especial u otros foros especializados en seguridad y asociaciones profesionales.

Objetivo

Garantizar que se produzca un flujo adecuado de información con respecto a la seguridad de la información.

Guía

La pertenencia a grupos o foros de intereses especiales debe considerarse como un medio para:

- a) mejorar el conocimiento sobre las mejores prácticas y mantenerse actualizado con la información de seguridad relevante;
- b) asegurarse de que la comprensión del entorno de seguridad de la información esté actualizada;
- c) recibir alertas tempranas de alertas, avisos y parches relacionados con ataques y vulnerabilidades;
- d) obtener acceso a asesoramiento especializado en seguridad de la información;
- e) compartir e intercambiar información sobre nuevas tecnologías, productos, servicios, amenazas o vulnerabilidades;
- f) proporcionar puntos de enlace adecuados cuando se trata de incidentes de seguridad de la información (ver [5.24](#) a [5.28](#)).

Otra información

Ninguna otra información.

5.7 Inteligencia de amenazas

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo # Detective # Correctivo	# Confidencialidad # Integridad # Disponibilidad	# Identificar #Detectar # Responder	# Threat_and_vulner- gestión_de_habilidades	# Defensa # Resiliencia

Control

La información relacionada con las amenazas a la seguridad de la información debe recopilarse y analizarse para generar información sobre amenazas.

Objetivo

Proporcionar conciencia del entorno de amenazas de la organización para que se puedan tomar las medidas de mitigación adecuadas.

Guía

La información sobre amenazas existentes o emergentes se recopila y analiza para:

- a) facilitar acciones informadas para evitar que las amenazas causen daño a la organización;
- b) reducir el impacto de tales amenazas.

La inteligencia de amenazas se puede dividir en tres capas, todas las cuales deben tenerse en cuenta:

- a) inteligencia de amenazas estratégicas: intercambio de información de alto nivel sobre el cambiante panorama de amenazas (por ejemplo, tipos de atacantes o tipos de ataques);
- b) inteligencia de amenazas tácticas: información sobre las metodologías, herramientas y tecnologías involucradas del atacante;
- c) inteligencia de amenazas operativas: detalles sobre ataques específicos, incluidos indicadores técnicos.

La inteligencia de amenazas debe ser:

- a) relevante (es decir, relacionado con la protección de la organización);
- b) perspicaz (es decir, proporcionar a la organización una comprensión precisa y detallada del panorama de amenazas);
- c) contextual, para brindar conciencia situacional (es decir, agregar contexto a la información en función del momento de los eventos, dónde ocurren, experiencias previas y prevalencia en organizaciones similares);
- d) procesable (es decir, la organización puede actuar sobre la información de manera rápida y efectiva).

Las actividades de inteligencia de amenazas deben incluir:

- a) establecer objetivos para la producción de inteligencia sobre amenazas;
- b) identificar, examinar y seleccionar fuentes de información internas y externas que sean necesarias y apropiadas para proporcionar la información requerida para la producción de inteligencia sobre amenazas;
- c) recopilar información de fuentes seleccionadas, que pueden ser internas y externas;
- d) procesar la información recopilada para prepararla para el análisis (por ejemplo, traduciendo, formateando o corroborando la información);
- e) analizar la información para comprender cómo se relaciona y es significativa para la organización;
- f) comunicarlo y compartirlo con personas relevantes en un formato que pueda ser entendido.

La inteligencia de amenazas debe analizarse y utilizarse posteriormente:

- a) implementando procesos para incluir información recopilada de fuentes de inteligencia de amenazas en los procesos de gestión de riesgos de seguridad de la información de la organización;
- b) como entrada adicional a controles técnicos preventivos y de detección como firewalls, sistema de detección de intrusos o soluciones antimalware;
- c) como entrada a los procesos y técnicas de prueba de seguridad de la información.

La organización debe compartir la inteligencia sobre amenazas con otras organizaciones de forma mutua para mejorar la inteligencia sobre amenazas en general.

Otra información

Las organizaciones pueden utilizar la inteligencia de amenazas para prevenir, detectar o responder a las amenazas. Las organizaciones pueden producir inteligencia sobre amenazas, pero normalmente reciben y hacen uso de la inteligencia sobre amenazas producida por otras fuentes.

La inteligencia de amenazas a menudo la proporcionan proveedores o asesores independientes, agencias gubernamentales o grupos colaborativos de inteligencia de amenazas.

La efectividad de los controles tales como [5.25](#), [8.7](#), [8.16](#) o [8.23](#), depende de la calidad de la inteligencia de amenazas disponible.

5.8 Seguridad de la información en la gestión de proyectos

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Identificar # Proteger	# Gobernanza	# Gobernanza_y_Ecosistema # Protección

Control

La seguridad de la información debe integrarse en la gestión de proyectos.

Objetivo

Para garantizar que los riesgos de seguridad de la información relacionados con proyectos y entregables se aborden de manera efectiva en la gestión de proyectos a lo largo del ciclo de vida del proyecto.

Guía

La seguridad de la información debe integrarse en la gestión del proyecto para garantizar que los riesgos de seguridad de la información se aborden como parte de la gestión del proyecto. Esto se puede aplicar a cualquier tipo de proyecto independientemente de su complejidad, tamaño, duración, disciplina o área de aplicación (p. ej., un proyecto para un proceso empresarial central, TIC, gestión de instalaciones u otros procesos de apoyo).

La gestión de proyectos en uso debe exigir que:

- los riesgos de seguridad de la información se evalúan y tratan en una etapa temprana y periódicamente como parte de los riesgos del proyecto a lo largo del ciclo de vida del proyecto;
- requisitos de seguridad de la información [por ejemplo, requisitos de seguridad de la aplicación ([8.26](#)), requisitos para cumplir con los derechos de propiedad intelectual ([5.32](#)), etc.] se abordan en las primeras etapas de los proyectos;
- los riesgos de seguridad de la información asociados con la ejecución de proyectos, como la seguridad de los aspectos de comunicación interna y externa, se consideran y tratan a lo largo del ciclo de vida del proyecto;
- se revisa el progreso en el tratamiento de riesgos de seguridad de la información y se evalúa y prueba la efectividad del tratamiento.

La idoneidad de las consideraciones y actividades de seguridad de la información debe ser objeto de seguimiento en etapas predefinidas por personas u órganos de gobierno adecuados, como el comité directivo del proyecto.

Las responsabilidades y autoridades para la seguridad de la información relevantes para el proyecto deben definirse y asignarse a roles específicos.

Los requisitos de seguridad de la información para los productos o servicios que entregará el proyecto deben determinarse utilizando varios métodos, incluida la derivación de los requisitos de cumplimiento de la política de seguridad de la información, las políticas y las reglamentaciones específicas del tema. Se pueden derivar otros requisitos de seguridad de la información de actividades como el modelado de amenazas, revisiones de incidentes, uso de umbrales de vulnerabilidad o planificación de contingencias, asegurando así que la arquitectura y el diseño de los sistemas de información estén protegidos contra amenazas conocidas basadas en el entorno operativo.

Los requisitos de seguridad de la información deben determinarse para todos los tipos de proyectos, no solo para los proyectos de desarrollo de TIC. También se debe considerar lo siguiente al determinar estos requisitos:

- a) qué información está involucrada (determinación de la información), cuáles son las necesidades de seguridad de la información correspondientes (clasificación; véase [5.12](#)) y el potencial impacto comercial negativo que puede resultar de la falta de seguridad adecuada;
- b) las necesidades de protección requeridas de la información y otros activos asociados involucrados, particularmente en términos de confidencialidad, integridad y disponibilidad;
- c) el nivel de confianza o seguridad requerido con respecto a la identidad reclamada de las entidades para derivar los requisitos de autenticación;
- d) acceder a procesos de aprovisionamiento y autorización, para clientes y otros usuarios comerciales potenciales, así como para usuarios privilegiados o técnicos, como miembros relevantes del proyecto, personal de operación potencial o proveedores externos;
- e) informar a los usuarios de sus deberes y responsabilidades;
- f) requisitos derivados de los procesos comerciales, como el registro y seguimiento de transacciones, requisitos de no repudio;
- g) requisitos exigidos por otros controles de seguridad de la información (por ejemplo, interfaces para registro y monitoreo o sistemas de detección de fuga de datos);
- h) cumplimiento del entorno legal, estatutario, reglamentario y contractual en el que opera la organización;
- i) el nivel de confianza o garantía requerido para que terceros cumplan con la política de seguridad de la información de la organización y las políticas específicas del tema, incluidas las cláusulas de seguridad relevantes en cualquier acuerdo o contrato.

Otra información

El enfoque de desarrollo del proyecto, como el ciclo de vida en cascada o el ciclo de vida ágil, debe respaldar la seguridad de la información de una manera estructurada que pueda adaptarse a la gravedad evaluada de los riesgos de seguridad de la información, según el carácter del proyecto. La consideración temprana de los requisitos de seguridad de la información para el producto o servicio (por ejemplo, en las etapas de planificación y diseño) puede conducir a soluciones más eficaces y rentables para la calidad y la seguridad de la información. ISO 21500 e ISO 21502 brindan orientación sobre conceptos y procesos de gestión de proyectos que son importantes para el desempeño de los proyectos.

ISO/IEC 27005 proporciona orientación sobre el uso de procesos de gestión de riesgos para identificar controles para cumplir con los requisitos de seguridad de la información.

5.9 Inventario de información y otros activos asociados

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Identificar	# Asset_manage- mento	# Gobernanza_y_Eco- proteccion del sistema

Control

Se debe desarrollar y mantener un inventario de información y otros activos asociados, incluidos los propietarios.

Objetivo

Identificar la información de la organización y otros activos asociados con el fin de preservar su seguridad de la información y asignar la propiedad adecuada.

Guía

Inventario

La organización debería identificar su información y otros activos asociados y determinar su importancia en términos de seguridad de la información. La documentación debe mantenerse en inventarios dedicados o existentes, según corresponda.

El inventario de información y otros activos asociados debe ser preciso, actualizado, consistente y alineado con otros inventarios. Las opciones para garantizar la precisión de un inventario de información y otros activos asociados incluyen:

- a) realizar revisiones periódicas de la información identificada y otros activos asociados contra el inventario de activos;
- b) hacer cumplir automáticamente una actualización de inventario en el proceso de instalación, cambio o eliminación de un activo.

La ubicación de un activo debe incluirse en el inventario según corresponda.

El inventario no necesita ser una lista única de información y otros activos asociados. Teniendo en cuenta que el inventario debe ser mantenido por las funciones pertinentes, puede verse como un conjunto de inventarios dinámicos, como inventarios de activos de información, hardware, software, máquinas virtuales (VM), instalaciones, personal, competencia, capacidades y registros.

Cada activo debe clasificarse de acuerdo con la clasificación de la información (ver [5.12](#)) asociado a ese activo.

La granularidad del inventario de información y otros activos asociados debe estar en un nivel apropiado para las necesidades de la organización. A veces, no es factible documentar instancias específicas de activos en el ciclo de vida de la información debido a la naturaleza del activo. Un ejemplo de un activo de corta duración es una instancia de VM cuyo ciclo de vida puede ser de corta duración.

Propiedad

Para la información identificada y otros activos asociados, la propiedad del activo debe asignarse a un individuo o grupo y debe identificarse la clasificación (ver [5.12](#), [5.13](#)). Debe implementarse un proceso para garantizar la asignación oportuna de la propiedad de los activos. La propiedad debe asignarse cuando se crean los activos o cuando se transfieren los activos a la organización. La propiedad de los activos debe reasignarse según sea necesario cuando los propietarios actuales de los activos se van o cambian de puesto.

deberes del propietario

El propietario del activo debe ser responsable de la gestión adecuada de un activo durante todo el ciclo de vida del activo, asegurando que:

- a) se inventarian la información y otros activos asociados;
- b) la información y otros activos asociados estén debidamente clasificados y protegidos;
- c) la clasificación se revisa periódicamente;
- d) se enumeran y vinculan los componentes que respaldan los activos tecnológicos, como bases de datos, almacenamiento, componentes y subcomponentes de software;
- e) requisitos para el uso aceptable de la información y otros activos asociados (ver [5.10](#)) están establecidos;
- f) las restricciones de acceso correspondan con la clasificación y que sean efectivas y se revisen periódicamente;
- g) la información y otros activos asociados, cuando se eliminan o eliminan, se manejen de manera segura y se eliminan del inventario;

- h) están involucrados en la identificación y gestión de riesgos asociados con su(s) activo(s);
- i) apoyan al personal que tiene los roles y responsabilidades de administrar su información.

Otra información

Los inventarios de información y otros activos asociados a menudo son necesarios para garantizar la protección efectiva de la información y pueden ser necesarios para otros fines, como salud y seguridad, seguros o razones financieras. Los inventarios de información y otros activos asociados también respaldan la gestión de riesgos, las actividades de auditoría, la gestión de vulnerabilidades, la respuesta a incidentes y la planificación de la recuperación.

Las tareas y responsabilidades se pueden delegar (por ejemplo, a un custodio que se ocupa de los activos diariamente), pero la persona o el grupo que las delegó sigue siendo responsable.

Puede ser útil designar grupos de información y otros activos asociados que actúan juntos para brindar un servicio particular. En este caso, el titular de este servicio es responsable de la prestación del servicio, incluida la explotación de sus activos.

Consulte ISO/IEC 19770-1 para obtener información adicional sobre la gestión de activos de tecnología de la información (TI). Consulte la norma ISO 55001 para obtener información adicional sobre la gestión de activos.

5.10 Uso aceptable de la información y otros activos asociados

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# Gestión de activos # Información_protección	# Gobernanza_y_Ecosistema # Protección

Control

Deben identificarse, documentarse e implementarse reglas para el uso aceptable y procedimientos para el manejo de la información y otros activos asociados.

Objetivo

Para garantizar que la información y otros activos asociados se protejan, utilicen y manejen adecuadamente.

Guía

El personal y los usuarios externos que utilicen o tengan acceso a la información de la organización y otros activos asociados deben conocer los requisitos de seguridad de la información para proteger y manejar la información de la organización y otros activos asociados. Deben ser responsables del uso que hagan de las instalaciones de procesamiento de información.

La organización debe establecer una política específica de un tema sobre el uso aceptable de la información y otros activos asociados y comunicarla a cualquier persona que use o maneje información y otros activos asociados. La política específica del tema sobre el uso aceptable debe proporcionar una dirección clara sobre cómo se espera que las personas usen la información y otros activos asociados. La política específica del tema debe establecer:

- a) comportamientos esperados e inaceptables de las personas desde una perspectiva de seguridad de la información;
- b) uso permitido y prohibido de información y otros activos asociados;
- c) las actividades de seguimiento que realiza la organización.

Deben elaborarse procedimientos de uso aceptable para todo el ciclo de vida de la información de acuerdo con su clasificación (ver [5.12](#)) y riesgos determinados. Se deben considerar los siguientes elementos:

- a) restricciones de acceso que respaldan los requisitos de protección para cada nivel de clasificación;
- b) mantenimiento de un registro de los usuarios autorizados de información y otros activos asociados;

- c) protección de copias temporales o permanentes de información a un nivel consistente con la protección de la información original;
- d) almacenamiento de activos asociados con la información de acuerdo con las especificaciones de los fabricantes (ver [7.8](#));
- e) marcado claro de todas las copias de los medios de almacenamiento (electrónicos o físicos) para la atención del destinatario autorizado (ver [7.10](#));
- f) autorización de eliminación de información y otros activos asociados y método(s) de eliminación admitidos (ver [8.10](#)).

Otra información

Puede darse el caso de que los activos en cuestión no pertenezcan directamente a la organización, como los servicios de nube pública. El uso de dichos activos de terceros y cualquier activo de la organización asociado con dichos activos externos (por ejemplo, información, software) debe identificarse como aplicable y controlarse, por ejemplo, a través de acuerdos con proveedores de servicios en la nube. También se debe tener cuidado cuando se utiliza un entorno de trabajo colaborativo.

5.11 Devolución de bienes

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# Asset_manage- mento	# Proteccion

Control

El personal y otras partes interesadas, según corresponda, deben devolver todos los activos de la organización que estén en su poder al cambiar o terminar su empleo, contrato o acuerdo.

Objetivo

Para proteger los activos de la organización como parte del proceso de cambio o terminación de empleo, contrato o acuerdo.

Guía

El proceso de cambio o terminación debe formalizarse para incluir la devolución de todos los activos físicos y electrónicos emitidos anteriormente que sean propiedad de la organización o estén encomendados a ella.

En los casos en que el personal y otras partes interesadas compren el equipo de la organización o usen su propio equipo personal, se deben seguir los procedimientos para garantizar que toda la información relevante sea rastreada y transferida a la organización y eliminada de manera segura del equipo (ver [7.14](#)).

En los casos en que el personal y otras partes interesadas tengan conocimientos que sean importantes para las operaciones en curso, esa información debe documentarse y transferirse a la organización.

Durante el período de notificación y posteriormente, la organización debe evitar la copia no autorizada de información relevante (por ejemplo, propiedad intelectual) por parte del personal bajo notificación de terminación.

La organización debe identificar y documentar claramente toda la información y otros activos asociados que se devolverán, que pueden incluir:

- a) dispositivos de punto extremo de usuario;
- b) dispositivos portátiles de almacenamiento;
- c) equipo especializado;

- d) hardware de autenticación (por ejemplo, llaves mecánicas, tokens físicos y tarjetas inteligentes) para sistemas de información, sitios y archivos físicos;
- e) copias físicas de la información.

Otra información

Puede ser difícil devolver la información que se tiene sobre los activos que no son propiedad de la organización. En tales casos, es necesario restringir el uso de la información utilizando otros controles de seguridad de la información, como la gestión de derechos de acceso (5.18) o uso de criptografía (8.24).

5.12 Clasificación de la información

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Identificar	#Información_pro- tección	# Proteccion # Defensa

Control

La información debe clasificarse de acuerdo con las necesidades de seguridad de la información de la organización en función de la confidencialidad, la integridad, la disponibilidad y los requisitos pertinentes de las partes interesadas.

Objetivo

Asegurar la identificación y comprensión de las necesidades de protección de la información de acuerdo con su importancia para la organización.

Guía

La organización debe establecer una política específica de un tema sobre la clasificación de la información y comunicarla a todas las partes interesadas pertinentes.

La organización debe tener en cuenta los requisitos de confidencialidad, integridad y disponibilidad en el esquema de clasificación.

Las clasificaciones y los controles de protección asociados para la información deben tener en cuenta las necesidades comerciales para compartir o restringir la información, proteger la integridad de la información y garantizar la disponibilidad, así como los requisitos legales relacionados con la confidencialidad, integridad o disponibilidad de la información. Los activos distintos de la información también pueden clasificarse de acuerdo con la clasificación de la información, que se almacena, procesa o maneja o protege de otro modo por el activo.

Los propietarios de la información deben ser responsables de su clasificación.

El esquema de clasificación debe incluir convenciones para la clasificación y criterios para la revisión de la clasificación a lo largo del tiempo. Los resultados de la clasificación deben actualizarse de acuerdo con los cambios del valor, la sensibilidad y la criticidad de la información a lo largo de su ciclo de vida.

El esquema debe estar alineado con la política específica del tema sobre el control de acceso (ver5.1) y debe ser capaz de abordar las necesidades comerciales específicas de la organización.

La clasificación puede ser determinada por el nivel de impacto que el compromiso de la información tendría para la organización. Cada nivel definido en el esquema debe recibir un nombre que tenga sentido en el contexto de la aplicación del esquema de clasificación.

El esquema debe ser consistente en toda la organización e incluirse en sus procedimientos para que todos clasifiquen la información y otros activos asociados aplicables de la misma manera. De esta manera, todos tienen un entendimiento común de los requisitos de protección y aplican la protección adecuada.

El esquema de clasificación utilizado dentro de la organización puede ser diferente de los esquemas utilizados por otras organizaciones, incluso si los nombres de los niveles son similares. Además, la información que se mueve entre

las organizaciones pueden variar en clasificación dependiendo de su contexto en cada organización, incluso si sus esquemas de clasificación son idénticos. Por lo tanto, los acuerdos con otras organizaciones que incluyen el intercambio de información deben incluir procedimientos para identificar la clasificación de esa información y para interpretar los niveles de clasificación de otras organizaciones. La correspondencia entre diferentes esquemas se puede determinar buscando la equivalencia en los métodos de manejo y protección asociados.

Otra información

La clasificación brinda a las personas que manejan información una indicación concisa de cómo manejarla y protegerla. La creación de grupos de información con necesidades de protección similares y la especificación de procedimientos de seguridad de la información que se aplican a toda la información de cada grupo facilita esto. Este enfoque reduce la necesidad de una evaluación de riesgos caso por caso y un diseño personalizado de los controles.

La información puede dejar de ser sensible o crítica después de un cierto período de tiempo. Por ejemplo, cuando la información se ha hecho pública, ya no tiene requisitos de confidencialidad pero aún puede requerir protección para sus propiedades de integridad y disponibilidad. Estos aspectos deben tenerse en cuenta, ya que la sobreclasificación puede llevar a la implementación de controles innecesarios que resulten en gastos adicionales o, por el contrario, la subclasificación puede llevar a controles insuficientes para proteger la información de compromisos.

A modo de ejemplo, un esquema de clasificación de la confidencialidad de la información puede basarse en los cuatro niveles siguientes:

- a) la divulgación no causa daño;
- b) la divulgación causa un daño reputacional menor o un impacto operativo menor;
- c) la divulgación tiene un impacto significativo a corto plazo en las operaciones o los objetivos comerciales;
- d) la divulgación tiene un impacto grave en los objetivos comerciales a largo plazo o pone en riesgo la supervivencia de la organización.

5.13 Etiquetado de la información

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# Información_ proteccion	# Defensa # Proteccion

Control

Se debe desarrollar e implementar un conjunto apropiado de procedimientos para el etiquetado de la información de acuerdo con el esquema de clasificación de la información adoptado por la organización.

Objetivo

Facilitar la comunicación de la clasificación de la información y apoyar la automatización del procesamiento y la gestión de la información.

Guía

Los procedimientos para el etiquetado de la información deben cubrir la información y otros activos asociados en todos los formatos. El etiquetado debe reflejar el esquema de clasificación establecido en [5.12](#). Las etiquetas deben ser fácilmente reconocibles. Los procedimientos deben brindar orientación sobre dónde y cómo se colocan las etiquetas teniendo en cuenta cómo se accede a la información o cómo se manejan los activos según los tipos de medios de almacenamiento. Los procedimientos pueden definir:

- a) casos en los que se omite el etiquetado (p. ej., etiquetado de información no confidencial para reducir la carga de trabajo);
- b) cómo etiquetar la información enviada o almacenada en medios electrónicos o físicos, o cualquier otro formato;

c) cómo manejar los casos en los que el etiquetado no es posible (por ejemplo, debido a restricciones técnicas).

Los ejemplos de técnicas de etiquetado incluyen:

a) etiquetas físicas;

b) encabezados y pies de página;

c) metadatos;

d) marca de agua;

e) sellos de goma.

La información digital debe utilizar metadatos para identificar, gestionar y controlar la información, especialmente en lo que respecta a la confidencialidad. Los metadatos también deben permitir una búsqueda eficiente y correcta de información. Los metadatos deben facilitar que los sistemas interactúen y tomen decisiones en función de las etiquetas de clasificación asociadas.

Los procedimientos deben describir cómo adjuntar metadatos a la información, qué etiquetas usar y cómo se deben manejar los datos, de acuerdo con el modelo de información y la arquitectura de TIC de la organización.

Los sistemas deben agregar metadatos adicionales relevantes cuando procesan información según sus propiedades de seguridad de la información.

El personal y otras partes interesadas deben conocer los procedimientos de etiquetado. Todo el personal debe recibir la capacitación necesaria para garantizar que la información se etiquete correctamente y se manipule en consecuencia.

Los resultados de los sistemas que contienen información clasificada como confidencial o crítica deben llevar una etiqueta de clasificación adecuada.

Otra información

El etiquetado de la información clasificada es un requisito clave para el intercambio de información.

Otros metadatos útiles que se pueden adjuntar a la información son qué proceso organizacional creó la información y en qué momento.

El etiquetado de la información y otros activos asociados a veces puede tener efectos negativos. Los activos clasificados pueden ser más fáciles de identificar por parte de actores maliciosos para un posible uso indebido.

Algunos sistemas no etiquetan archivos individuales o registros de bases de datos con su clasificación, pero protegen toda la información al más alto nivel de clasificación de cualquier información que contenga o que se le permita contener. Es habitual en dichos sistemas determinar y luego etiquetar la información cuando se exporta.

5.14 Transferencia de información

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# Gestión de activos # Información_protección	# Protección

Control

Deben existir reglas, procedimientos o acuerdos de transferencia de información para todos los tipos de instalaciones de transferencia dentro de la organización y entre la organización y otras partes.

Objetivo

Para mantener la seguridad de la información transferida dentro de una organización y con cualquier parte externa interesada.

Guía

General

La organización debe establecer y comunicar una política específica del tema sobre la transferencia de información a todas las partes interesadas pertinentes. Las reglas, procedimientos y acuerdos para proteger la información en tránsito deben reflejar la clasificación de la información involucrada. Cuando se transfiera información entre la organización y terceros, se deben establecer y mantener acuerdos de transferencia (incluida la autenticación del destinatario) para proteger la información en todas las formas en tránsito (ver [5.10](#)).

La transferencia de información puede ocurrir a través de transferencia electrónica, transferencia de medios de almacenamiento físico y transferencia verbal.

Para todo tipo de transferencia de información, las reglas, procedimientos y acuerdos deben incluir:

- a) controles diseñados para proteger la información transferida de la interceptación, el acceso no autorizado, la copia, la modificación, el enrutamiento incorrecto, la destrucción y la denegación de servicio, incluidos los niveles de control de acceso acordes con la clasificación de la información involucrada y cualquier control especial que se requiera para proteger la información confidencial, como el uso de técnicas criptográficas (ver [8.24](#));
- b) controles para garantizar la trazabilidad y el no repudio, incluido el mantenimiento de una cadena de custodia de la información durante el tránsito;
- c) identificación de los contactos apropiados relacionados con la transferencia, incluidos los propietarios de la información, los propietarios del riesgo, los oficiales de seguridad y los custodios de la información, según corresponda;
- d) responsabilidades y obligaciones en caso de incidentes de seguridad de la información, como la pérdida de medios físicos de almacenamiento o datos;
- e) uso de un sistema de etiquetado acordado para información sensible o crítica, asegurando que el significado de las etiquetas se entienda de inmediato y que la información esté debidamente protegida (ver [5.13](#));
- f) confiabilidad y disponibilidad del servicio de transferencia;
- g) la política o directrices específicas del tema sobre el uso aceptable de las instalaciones de transferencia de información (ver [5.10](#));
- h) pautas de retención y eliminación para todos los registros comerciales, incluidos los mensajes;

NOTA Pueden existir leyes y reglamentos locales con respecto a la retención y eliminación de registros comerciales.

- i) la consideración de cualquier otro requisito legal, estatutario, reglamentario y contractual relevante (ver [5.31](#), [5.32](#), [5.33](#), [5.34](#)) relacionados con la transferencia de información (por ejemplo, requisitos para las firmas electrónicas).

Transferencia electrónica

Las reglas, los procedimientos y los acuerdos también deben considerar los siguientes elementos al utilizar las instalaciones de comunicación electrónica para la transferencia de información:

- a) detección y protección contra malware que puede transmitirse mediante el uso de comunicaciones electrónicas (ver [8.7](#));
- b) protección de la información electrónica sensible comunicada que se encuentra en forma de archivo adjunto;
- c) prevención contra el envío de documentos y mensajes en las comunicaciones a la dirección o número equivocado;

- d) obtener aprobación antes de utilizar servicios públicos externos, como mensajería instantánea, redes sociales, uso compartido de archivos o almacenamiento en la nube;
- e) niveles más fuertes de autenticación al transferir información a través de redes de acceso público;
- f) restricciones asociadas con las instalaciones de comunicación electrónica (p. ej., impedir el reenvío automático de correo electrónico a direcciones de correo externas);
- g) advertir al personal y otras partes interesadas que no envíen servicios de mensajes cortos (SMS) o mensajes instantáneos con información crítica ya que estos pueden ser leídos en lugares públicos (y por lo tanto por personas no autorizadas) o almacenados en dispositivos no protegidos adecuadamente;
- h) asesorar al personal y otras partes interesadas sobre los problemas de uso de máquinas o servicios de fax, a saber:
 - 1) acceso no autorizado a los almacenes de mensajes incorporados para recuperar mensajes;
 - 2) programación deliberada o accidental de máquinas para enviar mensajes a números específicos.

Transferencia de medios de almacenamiento físico

Al transferir medios físicos de almacenamiento (incluido el papel), las reglas, los procedimientos y los acuerdos también deben incluir:

- a) responsabilidades de control y notificación de la transmisión, despacho y recepción;
- b) asegurar el correcto direccionamiento y transporte del mensaje;
- c) embalaje que proteja el contenido de cualquier daño físico que pueda surgir durante el tránsito y de acuerdo con las especificaciones de los fabricantes, por ejemplo, protegiendo contra cualquier factor ambiental que pueda reducir la eficacia de la restauración de los medios de almacenamiento, como la exposición al calor, la humedad o la radiación electromagnética. campos; utilizar normas técnicas mínimas para el embalaje y la transmisión (por ejemplo, el uso de sobres opacos);
- d) una lista de mensajeros confiables autorizados acordados por la administración;
- e) estándares de identificación del mensajero;
- f) dependiendo del nivel de clasificación de la información en los medios de almacenamiento a ser transportados, usar controles a prueba de manipulaciones o inviolables (por ejemplo, bolsas, contenedores);
- g) procedimientos para verificar la identificación de los correos;
- h) lista aprobada de terceros que prestan servicios de transporte o mensajería según la clasificación de la información;
- i) llevar registros para identificar el contenido de los medios de almacenamiento, la protección aplicada, así como registrar la lista de destinatarios autorizados, los tiempos de transferencia a los custodios de tránsito y la recepción en destino.

transferencia verbal

Para proteger la transferencia verbal de información, se debe recordar al personal y otras partes interesadas que deben:

- a) no tener conversaciones verbales confidenciales en lugares públicos o por canales de comunicación inseguros, ya que pueden ser escuchadas por personas no autorizadas;
- b) no dejar mensajes que contengan información confidencial en contestadores automáticos o mensajes de voz, ya que estos pueden ser reproducidos por personas no autorizadas, almacenados en sistemas comunales o almacenados incorrectamente como resultado de una marcación incorrecta;
- c) ser proyectado al nivel apropiado para escuchar la conversación;

- d) asegurarse de que se implementen los controles de sala adecuados (p. ej., insonorización, puertas cerradas);
- e) comenzar cualquier conversación delicada con un descargo de responsabilidad para que los presentes sepan el nivel de clasificación y los requisitos de manejo de lo que están a punto de escuchar.

Otra información

Ninguna otra información.

5.15 Control de acceso

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	#identidad_y_ac- cess_management	# Proteccion

Control

Las reglas para controlar el acceso físico y lógico a la información y otros activos asociados deben establecerse e implementarse en función de los requisitos comerciales y de seguridad de la información.

Objetivo

Para garantizar el acceso autorizado y evitar el acceso no autorizado a la información y otros activos asociados.

Guía

Los propietarios de la información y otros activos asociados deben determinar la seguridad de la información y los requisitos comerciales relacionados con el control de acceso. Debe definirse una política específica de tema sobre control de acceso que tenga en cuenta estos requisitos y debe comunicarse a todas las partes interesadas pertinentes.

Estos requisitos y la política específica del tema deben considerar lo siguiente:

- determinar qué entidades requieren qué tipo de acceso a la información y otros activos asociados;
- seguridad de las aplicaciones (ver [8.26](#));
- acceso físico, que debe estar respaldado por controles de entrada físicos apropiados (ver [7.2](#), [7.3](#), [7.4](#));
- diseminación y autorización de la información (por ejemplo, el principio de necesidad de saber) y niveles de seguridad de la información y clasificación de la información (ver [5.10](#), [5.12](#), [5.13](#));
- restricciones al acceso privilegiado (ver [8.2](#));
- segregación de funciones (ver [5.3](#));
- la legislación, los reglamentos y las obligaciones contractuales pertinentes con respecto a la limitación del acceso a datos o servicios (ver [5.31](#), [5.32](#), [5.33](#), [5.34](#), [8.3](#));
- segregación de las funciones de control de acceso (por ejemplo, solicitud de acceso, autorización de acceso, administración de acceso);
- autorización formal de solicitudes de acceso (ver [5.16](#) y [5.18](#));
- la gestión de los derechos de acceso (ver [5.18](#));
- registro (ver [8.15](#)).

Las reglas de control de acceso deben implementarse definiendo y mapeando los derechos y restricciones de acceso apropiados para las entidades relevantes (ver [5.16](#)). Una entidad puede representar tanto a un usuario humano como a un elemento técnico o lógico (por ejemplo, una máquina, un dispositivo o un servicio). Para simplificar la gestión del control de acceso, se pueden asignar roles específicos a grupos de entidades.

Se debe tener en cuenta lo siguiente al definir e implementar reglas de control de acceso:

- a) coherencia entre los derechos de acceso y la clasificación de la información;
- b) coherencia entre los derechos de acceso y las necesidades y requisitos de seguridad del perímetro físico;
- c) considerar todos los tipos de conexiones disponibles en entornos distribuidos para que las entidades solo tengan acceso a la información y otros activos asociados, incluidas las redes y los servicios de red, que están autorizadas a usar;
- d) considerar cómo se pueden reflejar los elementos o factores relevantes para el control de acceso dinámico.

Otra información

A menudo se utilizan principios generales en el contexto del control de acceso. Dos de los principios más utilizados son:

- a) necesidad de saber: una entidad solo tiene acceso a la información que esa entidad requiere para realizar sus tareas (diferentes tareas o roles significan diferente información de necesidad de saber y, por lo tanto, diferentes perfiles de acceso);
- b) necesidad de uso: a una entidad solo se le asigna acceso a la infraestructura de tecnología de la información cuando existe una necesidad clara.

Se debe tener cuidado al especificar reglas de control de acceso para considerar:

- a) establecer reglas basadas en la premisa del privilegio mínimo, "Todo está generalmente prohibido a menos que esté expresamente permitido", en lugar de la regla más débil, "Todo está generalmente permitido a menos que esté expresamente prohibido";
- b) cambios en las etiquetas de información (ver [5.13](#)) que son iniciados automáticamente por las instalaciones de procesamiento de información y aquellos iniciados a discreción de un usuario;
- c) cambios en los permisos de usuario que son iniciados automáticamente por el sistema de información y aquellos iniciados por un administrador;
- d) cuándo definir y revisar periódicamente la aprobación.

Las reglas de control de acceso deben estar respaldadas por procedimientos documentados (ver [5.16](#), [5.17](#), [5.18](#), [8.2](#), [8.3](#), [8.4](#), [8.5](#), [8.18](#)) y responsabilidades definidas (ver [5.2](#), [5.17](#)).

Hay varias formas de implementar el control de acceso, como MAC (control de acceso obligatorio), DAC (control de acceso discrecional), RBAC (control de acceso basado en roles) y ABAC (control de acceso basado en atributos).

Las reglas de control de acceso también pueden contener elementos dinámicos (por ejemplo, una función que evalúa accesos anteriores o valores de entorno específicos). Las reglas de control de acceso se pueden implementar en diferentes granularidades, que van desde cubrir redes o sistemas completos hasta campos de datos específicos y también pueden considerar propiedades como la ubicación del usuario o el tipo de conexión de red que se utiliza para el acceso. Estos principios y cómo se define el control de acceso granular pueden tener un impacto significativo en los costos. Reglas más estrictas y más granularidad generalmente conducen a un costo más alto. Los requisitos comerciales y las consideraciones de riesgo deben usarse para definir qué reglas de control de acceso se aplican y qué granularidad se requiere.

5.16 Gestión de identidad

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	#identidad_y_ac- cess_management	# Protección

Control

Debe gestionarse el ciclo de vida completo de las identidades.

Objetivo

Permitir la identificación única de personas y sistemas que acceden a la información de la organización y otros activos asociados y permitir la asignación adecuada de derechos de acceso.

Guía

Los procesos utilizados en el contexto de la gestión de la identidad deben garantizar que:

- para las identidades asignadas a personas, una identidad específica solo se vincula a una sola persona para poder responsabilizar a la persona por las acciones realizadas con esta identidad específica;
- las identidades asignadas a varias personas (por ejemplo, identidades compartidas) solo se permiten cuando son necesarias por razones comerciales u operativas y están sujetas a aprobación y documentación específicas;
- las identidades asignadas a entidades no humanas están sujetas a una aprobación segregada adecuada y a una supervisión continua independiente;
- las identidades se inhabilitan o eliminan de manera oportuna si ya no son necesarias (por ejemplo, si sus entidades asociadas se eliminan o ya no se utilizan, o si la persona vinculada a una identidad ha dejado la organización o ha cambiado de función);
- en un dominio específico, una sola identidad se mapea a una sola entidad, [es decir, se evita el mapeo de múltiples identidades a la misma entidad dentro del mismo contexto (identidades duplicadas)];
- se mantienen registros de todos los eventos significativos relacionados con el uso y la gestión de las identidades de los usuarios y de la información de autenticación.

La organización debe contar con un proceso de soporte para manejar los cambios en la información relacionada con las identidades de los usuarios. Estos procesos pueden incluir la reverificación de documentos confiables relacionados con una persona.

Al utilizar identidades proporcionadas o emitidas por terceros (p. ej., credenciales de redes sociales), la organización debe asegurarse de que las identidades de terceros brinden el nivel de confianza requerido y que los riesgos asociados se conozcan y se traten adecuadamente. Esto puede incluir controles relacionados con terceros (ver [5.19](#)), así como los controles relacionados con la información de autenticación asociada (ver [5.17](#)).

Otra información

Proporcionar o revocar el acceso a la información y otros activos asociados suele ser un procedimiento de varios pasos:

- confirmar los requisitos comerciales para establecer una identidad;
- verificar la identidad de una entidad antes de asignarles una identidad lógica;
- establecer una identidad;
- configurar y activar la identidad. Esto también incluye la configuración y configuración inicial de los servicios de autenticación relacionados;

e) otorgar o revocar derechos de acceso específicos a la identidad, con base en las decisiones de autorización o derecho correspondientes (ver [5.18](#)).

5.17 Información de autenticación

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# identidad_y_ac- cess_management	# Protección

Control

La asignación y gestión de la información de autenticación debe controlarse mediante un proceso de gestión, incluido el asesoramiento al personal sobre el manejo adecuado de la información de autenticación.

Objetivo

Para garantizar la autenticación adecuada de la entidad y evitar fallas en los procesos de autenticación.

Guía

Asignación de información de autenticación

El proceso de asignación y gestión debe garantizar que:

- a) las contraseñas personales o los números de identificación personal (PIN) generados automáticamente durante los procesos de inscripción como información de autenticación secreta temporal no se pueden adivinar y son únicos para cada persona, y los usuarios deben cambiarlos después del primer uso;
- b) se establecen procedimientos para verificar la identidad de un usuario antes de proporcionar información de autenticación nueva, de reemplazo o temporal;
- c) la información de autenticación, incluida la información de autenticación temporal, se transmite a los usuarios de manera segura (por ejemplo, a través de un canal autenticado y protegido) y se evita el uso de mensajes de correo electrónico sin protección (texto claro) para este propósito;
- d) los usuarios acusan recibo de la información de autenticación;
- e) la información de autenticación predeterminada predefinida o proporcionada por los proveedores se cambia inmediatamente después de la instalación de sistemas o software;
- f) se mantienen registros de eventos significativos relacionados con la asignación y gestión de la información de autenticación y se garantiza su confidencialidad, y se aprueba el método de mantenimiento de registros (p. ej. utilizando una herramienta de bóveda de contraseñas aprobada).

Responsabilidades del usuario

Cualquier persona que tenga acceso o utilice información de autenticación debe ser advertida de que se asegure de que:

- a) la información de autenticación secreta, como las contraseñas, se mantiene confidencial. La información de autenticación secreta personal no debe compartirse con nadie. La información de autenticación secreta utilizada en el contexto de identidades vinculadas a múltiples usuarios o vinculadas a entidades no personales se comparte únicamente con personas autorizadas;
- b) la información de autenticación afectada o comprometida se cambia inmediatamente después de la notificación o cualquier otra indicación de un compromiso;
- c) cuando se utilizan contraseñas como información de autenticación, se seleccionan contraseñas seguras de acuerdo con las recomendaciones de las mejores prácticas, por ejemplo:

- 1) las contraseñas no se basan en nada que otra persona pueda adivinar u obtener fácilmente utilizando información relacionada con la persona (por ejemplo, nombres, números de teléfono y fechas de nacimiento);
- 2) las contraseñas no se basan en palabras del diccionario o combinaciones de las mismas;
- 3) use frases de contraseña fáciles de recordar e intente incluir caracteres alfanuméricos y especiales;
- 4) las contraseñas tienen una longitud mínima;
- d) las mismas contraseñas no se utilizan en distintos servicios y sistemas;
- e) la obligación de seguir estas reglas también está incluida en los términos y condiciones de empleo (ver [6.2](#)).

Sistema de gestión de contraseñas

Cuando se utilizan contraseñas como información de autenticación, el sistema de administración de contraseñas debe:

- a) permitir a los usuarios seleccionar y cambiar sus propias contraseñas e incluir un procedimiento de confirmación para abordar los errores de entrada;
- b) aplicar contraseñas seguras de acuerdo con las recomendaciones de buenas prácticas [ver c) de "Responsabilidades del usuario];
- c) obligar a los usuarios a cambiar sus contraseñas en el primer inicio de sesión;
- d) hacer cumplir los cambios de contraseña según sea necesario, por ejemplo, después de un incidente de seguridad, o al terminar o cambiar de empleo cuando un usuario tiene contraseñas conocidas para identidades que permanecen activas (por ejemplo, identidades compartidas);
- e) evitar la reutilización de contraseñas anteriores;
- f) evitar el uso de contraseñas de uso común y nombres de usuario comprometidos, combinaciones de contraseñas de sistemas pirateados;
- g) no mostrar contraseñas en la pantalla cuando se ingresan;
- h) almacenar y transmitir contraseñas en forma protegida.

El cifrado y el hashing de contraseñas deben realizarse de acuerdo con las técnicas criptográficas aprobadas para contraseñas (ver [8.24](#)).

Otra información

Las contraseñas o frases de contraseña son un tipo de información de autenticación de uso común y son un medio común para verificar la identidad de un usuario. Otros tipos de información de autenticación son claves criptográficas, datos almacenados en tokens de hardware (por ejemplo, tarjetas inteligentes) que producen códigos de autenticación y datos biométricos, como escaneos de iris o huellas dactilares. Se puede encontrar información adicional en la serie ISO/IEC 24760.

Requerir cambios frecuentes de contraseñas puede ser problemático porque los usuarios pueden molestarse por los cambios frecuentes, olvidar nuevas contraseñas, anotarlas en lugares inseguros o elegir contraseñas no seguras. La provisión de inicio de sesión único (SSO) u otras herramientas de gestión de autenticación (por ejemplo, bóvedas de contraseñas) reduce la cantidad de información de autenticación que los usuarios deben proteger y, por lo tanto, puede aumentar la eficacia de este control. Sin embargo, estas herramientas también pueden aumentar el impacto de la divulgación de información de autenticación.

Algunas aplicaciones requieren que una autoridad independiente asigne contraseñas de usuario. En tales casos, a), c) y d) del "Sistema de gestión de contraseñas" no se aplican.

5.18 Derechos de acceso

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	#identidad_y_ac- cess_management	# Proteccion

Control

Los derechos de acceso a la información y otros activos asociados deben proporcionarse, revisarse, modificarse y eliminarse de acuerdo con la política y las reglas de control de acceso específicas del tema de la organización.

Objetivo

Para garantizar que el acceso a la información y otros activos asociados se defina y autorice de acuerdo con los requisitos comerciales.

Guía

Concesión y revocación de los derechos de acceso

El proceso de aprovisionamiento para asignar o revocar los derechos de acceso físico y lógico otorgados a la identidad autenticada de una entidad debe incluir:

- obtener autorización del propietario de la información y otros activos asociados para el uso de la información y otros activos asociados (ver [5.9](#)). La aprobación por separado de los derechos de acceso por parte de la gerencia también puede ser apropiada;
- considerando los requisitos comerciales y la política y las reglas específicas del tema de la organización sobre el control de acceso;
- considerar la segregación de funciones, incluida la segregación de las funciones de aprobación e implementación de los derechos de acceso y la separación de funciones en conflicto;
- garantizar que los derechos de acceso se eliminen cuando alguien no necesite acceder a la información y otros activos asociados, en particular garantizar que los derechos de acceso de los usuarios que han dejado la organización se eliminen de manera oportuna;
- considerar otorgar derechos de acceso temporal por un período de tiempo limitado y revocarlos en la fecha de vencimiento, en particular para el personal temporal o el acceso temporal requerido por el personal;
- verificar que el nivel de acceso otorgado esté de acuerdo con las políticas específicas del tema sobre control de acceso (ver [5.15](#)) y es coherente con otros requisitos de seguridad de la información, como la segregación de funciones (ver [5.3](#));
- garantizar que los derechos de acceso se activen (por ejemplo, por parte de los proveedores de servicios) solo después de que se completen con éxito los procedimientos de autorización;
- mantener un registro central de los derechos de acceso otorgados a un identificador de usuario (ID, lógico o físico) para acceder a la información y otros activos asociados;
- modificar los derechos de acceso de los usuarios que han cambiado de rol o trabajo;
- eliminar o ajustar los derechos de acceso físico y lógico, lo que puede hacerse mediante la eliminación, revocación o reemplazo de claves, información de autenticación, tarjetas de identificación o suscripciones;
- mantener un registro de cambios en los derechos de acceso lógico y físico de los usuarios.

Revisión de los derechos de acceso

Las revisiones regulares de los derechos de acceso físico y lógico deben considerar lo siguiente:

- a) los derechos de acceso de los usuarios después de cualquier cambio dentro de la misma organización (por ejemplo, cambio de trabajo, promoción, descenso) o terminación del empleo (ver [6.1](#) a [6.5](#));
- b) autorizaciones de derechos de acceso privilegiado.

Consideración antes del cambio o terminación del empleo

Los derechos de acceso de un usuario a la información y otros activos asociados deben revisarse y ajustarse o eliminarse antes de cualquier cambio o terminación del empleo en función de la evaluación de factores de riesgo tales como:

- a) si la terminación o cambio es iniciado por el usuario o por la administración y el motivo de la terminación;
- b) las responsabilidades actuales del usuario;
- c) el valor de los activos actualmente accesibles.

Otra información

Se debe considerar el establecimiento de roles de acceso de usuario en función de los requisitos comerciales que resumen una serie de derechos de acceso en perfiles de acceso de usuario típicos. Las solicitudes de acceso y las revisiones de los derechos de acceso se gestionan más fácilmente a nivel de dichos roles que a nivel de derechos particulares.

Se debe considerar la posibilidad de incluir cláusulas en los contratos de personal y de servicios que especifiquen sanciones si el personal intenta acceder sin autorización (ver [5.20](#), [6.2](#), [6.4](#), [6.6](#)).

En casos de rescisión iniciada por la gerencia, el personal descontento o los usuarios externos pueden corromper deliberadamente la información o sabotear las instalaciones de procesamiento de información. En los casos de personas que renuncian o son despedidas, pueden verse tentados a recopilar información para uso futuro.

La clonación es una forma eficiente para que las organizaciones asignen acceso a los usuarios. Sin embargo, debe hacerse con cuidado en función de los distintos roles identificados por la organización en lugar de simplemente clonar una identidad con todos los derechos de acceso asociados. La clonación tiene un riesgo inherente de dar lugar a derechos de acceso excesivos a la información y otros activos asociados.

5.19 Seguridad de la información en las relaciones con los proveedores

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Identificar	# relación_proveedor- barcos_seguridad	# Gobernanza_y_ Ecosistema #Protec- ción

Control

Deben definirse e implementarse procesos y procedimientos para gestionar los riesgos de seguridad de la información asociados con el uso de los productos o servicios del proveedor.

Objetivo

Mantener un nivel acordado de seguridad de la información en las relaciones con los proveedores.

Guía

La organización debe establecer y comunicar una política específica del tema sobre las relaciones con los proveedores a todas las partes interesadas relevantes.

La organización debería identificar e implementar procesos y procedimientos para abordar los riesgos de seguridad asociados con el uso de productos y servicios proporcionados por los proveedores. Esto también debería aplicarse al uso que hace la organización de los recursos de los proveedores de servicios en la nube. Estos procesos y procedimientos deben incluir aquellos que debe implementar la organización, así como aquellos que la organización requiere que el proveedor implemente para el comienzo del uso de los productos o servicios de un proveedor o para la terminación del uso de los productos y servicios de un proveedor, tales como como:

- a) identificar y documentar los tipos de proveedores (por ejemplo, servicios de TIC, logística, servicios públicos, servicios financieros, componentes de infraestructura de TIC) que pueden afectar la confidencialidad, integridad y disponibilidad de la información de la organización;
- b) establecer cómo evaluar y seleccionar proveedores de acuerdo con la sensibilidad de la información, productos y servicios (por ejemplo, con análisis de mercado, referencias de clientes, revisión de documentos, evaluaciones in situ, certificaciones);
- c) evaluar y seleccionar productos o servicios del proveedor que cuenten con controles adecuados de seguridad de la información y revisarlos; en particular, la precisión y exhaustividad de los controles implementados por el proveedor que aseguren la integridad de la información del proveedor y el procesamiento de la información y, por lo tanto, la seguridad de la información de la organización;
- d) definir la información de la organización, los servicios TIC y la infraestructura física a la que los proveedores pueden acceder, monitorear, controlar o utilizar;
- e) definir los tipos de componentes y servicios de infraestructura TIC proporcionados por los proveedores que pueden afectar la confidencialidad, integridad y disponibilidad de la información de la organización;
- f) evaluar y gestionar los riesgos de seguridad de la información asociados con:
 - 1) el uso por parte de los proveedores de la información de la organización y otros activos asociados, incluidos los riesgos que se originan del personal del proveedor potencialmente malicioso;
 - 2) mal funcionamiento o vulnerabilidades de los productos (incluidos los componentes y subcomponentes de software utilizados en estos productos) o servicios proporcionados por los proveedores;
- g) monitorear el cumplimiento de los requisitos de seguridad de la información establecidos para cada tipo de proveedor y tipo de acceso, incluida la revisión por terceros y la validación del producto;
- h) mitigar el incumplimiento de un proveedor, ya sea que este haya sido detectado a través del monitoreo o por otros medios;
- i) el manejo de incidentes y contingencias asociadas con los productos y servicios del proveedor, incluidas las responsabilidades tanto de la organización como de los proveedores;
- j) resiliencia y, si es necesario, medidas de recuperación y contingencia para asegurar la disponibilidad de la información del proveedor y el procesamiento de la información y, por lo tanto, la disponibilidad de la información de la organización;
- k) concientización y capacitación para el personal de la organización que interactúa con el personal del proveedor con respecto a las reglas apropiadas de participación, políticas, procesos y procedimientos específicos del tema y comportamiento en función del tipo de proveedor y el nivel de acceso del proveedor a los sistemas e información de la organización;
- l) administrar la transferencia necesaria de información, otros activos asociados y cualquier otra cosa que deba cambiarse y garantizar que la seguridad de la información se mantenga durante todo el período de transferencia;
- m) requisitos para asegurar una terminación segura de la relación con el proveedor, incluyendo:
 - 1) desaprovechamiento de los derechos de acceso;
 - 2) manejo de la información;

3) determinar la propiedad de la propiedad intelectual desarrollada durante el compromiso;

4) portabilidad de la información en caso de cambio de proveedor o internalización;

6) gestión de registros;

7) devolución de bienes;

8) eliminación segura de información y otros activos asociados;

9) requisitos continuos de confidencialidad;

n) nivel de seguridad del personal y seguridad física que se espera del personal y las instalaciones del proveedor.

Se deben considerar los procedimientos para continuar con el procesamiento de la información en caso de que el proveedor no pueda suministrar sus productos o servicios (por ejemplo, debido a un incidente, porque el proveedor ya no está en el negocio o ya no proporciona algunos componentes debido a los avances tecnológicos). para evitar cualquier retraso en la organización de productos o servicios de reemplazo (por ejemplo, identificar un proveedor alternativo por adelantado o utilizar siempre proveedores alternativos).

Otra información

En los casos en que no sea posible para una organización imponer requisitos a un proveedor, la organización debería:

a) considerar la orientación dada en este control al tomar decisiones sobre la elección de un proveedor y su producto o servicio;

b) implementar controles de compensación según sea necesario con base en una evaluación de riesgos.

La información puede ser puesta en riesgo por proveedores con una gestión de seguridad de la información inadecuada. Deben determinarse y aplicarse controles para administrar el acceso del proveedor a la información y otros activos asociados. Por ejemplo, si existe una necesidad especial de confidencialidad de la información, se pueden utilizar acuerdos de confidencialidad o técnicas criptográficas. Otro ejemplo son los riesgos de protección de datos personales cuando el acuerdo con el proveedor implica la transferencia o el acceso a información a través de las fronteras. La organización debe ser consciente de que la responsabilidad legal o contractual de proteger la información sigue siendo de la organización.

Los riesgos también pueden ser causados por controles inadecuados de los componentes o servicios de infraestructura de TIC proporcionados por los proveedores. Los componentes o servicios defectuosos o vulnerables pueden provocar violaciones de la seguridad de la información en la organización o en otra entidad (p. ej., pueden provocar infecciones de malware, ataques u otros daños en entidades distintas a la organización).

Ver ISO/IEC 27036-2 para más detalles.

5.20 Abordar la seguridad de la información en los acuerdos con proveedores

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Identificar	# relación_proveedor- barcos_seguridad	# Gobernanza_y_ Ecosistema #Protec- ción

Control

Los requisitos de seguridad de la información pertinentes deben establecerse y acordarse con cada proveedor en función del tipo de relación con el proveedor.

Objetivo

Mantener un nivel acordado de seguridad de la información en las relaciones con los proveedores.

Guía

Los acuerdos con los proveedores deben establecerse y documentarse para garantizar que haya un entendimiento claro entre la organización y el proveedor con respecto a las obligaciones de ambas partes para cumplir con los requisitos de seguridad de la información pertinentes.

Se puede considerar la inclusión de los siguientes términos en los acuerdos para satisfacer los requisitos de seguridad de la información identificados:

- a) descripción de la información que se proporcionará o se accederá y los métodos para proporcionar o acceder a la información;
- b) clasificación de la información de acuerdo con el esquema de clasificación de la organización (ver [5.10](#), [5.12](#), [5.13](#));
- c) mapeo entre el esquema de clasificación propio de la organización y el esquema de clasificación del proveedor;
- d) requisitos legales, estatutarios, reglamentarios y contractuales, incluida la protección de datos, el manejo de información de identificación personal (PII), los derechos de propiedad intelectual y los derechos de autor y una descripción de cómo se garantizará que se cumplan;
- e) obligación de cada parte contractual de implementar un conjunto de controles acordado, incluido el control de acceso, revisión del desempeño, monitoreo, informes y auditoría, y las obligaciones del proveedor de cumplir con los requisitos de seguridad de la información de la organización;
- f) reglas de uso aceptable de la información y otros activos asociados, incluido el uso inaceptable si es necesario;
- g) procedimientos o condiciones para la autorización y revocación de la autorización para el uso de la información de la organización y otros activos asociados por parte del personal del proveedor (por ejemplo, a través de una lista explícita del personal del proveedor autorizado para usar la información de la organización y otros activos asociados);
- h) requisitos de seguridad de la información con respecto a la infraestructura TIC del proveedor; en particular, los requisitos mínimos de seguridad de la información para cada tipo de información y tipo de acceso para que sirvan como base para los acuerdos de proveedores individuales basados en las necesidades comerciales de la organización y los criterios de riesgo;
- i) indemnizaciones y remediación por incumplimiento de los requisitos por parte del contratista;
- j) requisitos y procedimientos de gestión de incidentes (especialmente notificación y colaboración durante la remediación de incidentes);
- k) requisitos de capacitación y concientización para procedimientos específicos y requisitos de seguridad de la información (p. ej., para respuesta a incidentes, procedimientos de autorización);
- l) disposiciones relevantes para la subcontratación, incluidos los controles que deben implementarse, como un acuerdo sobre el uso de subproveedores (por ejemplo, exigir que tengan las mismas obligaciones que el proveedor, exigir tener una lista de subcontratistas) proveedores y notificación ante cualquier cambio);
- m) contactos relevantes, incluida una persona de contacto para cuestiones de seguridad de la información;
- n) cualquier requisito de evaluación, cuando sea legalmente permisible, para el personal del proveedor, incluidas las responsabilidades de realizar los procedimientos de evaluación y notificación si la evaluación no se ha completado o si los resultados generan dudas o inquietudes;
- o) los mecanismos de evidencia y aseguramiento de certificaciones de terceros para los requisitos de seguridad de la información relevantes relacionados con los procesos del proveedor y un informe independiente sobre la efectividad de los controles;
- p) derecho a auditar los procesos y controles del proveedor relacionados con el contrato;

- q) obligación del proveedor de entregar periódicamente un informe sobre la efectividad de los controles y acuerdo sobre la corrección oportuna de las cuestiones relevantes planteadas en el informe;
- r) procesos de resolución de defectos y resolución de conflictos;
- s) proporcionar respaldo alineado con las necesidades de la organización (en términos de frecuencia y tipo y ubicación de almacenamiento);
- t) garantizar la disponibilidad de una instalación alternativa (es decir, un sitio de recuperación de desastres) que no esté sujeta a las mismas amenazas que la instalación principal y las consideraciones para los controles alternativos (controles alternativos) en caso de que fallen los controles principales;
- u) tener un proceso de gestión de cambios que asegure la notificación previa a la organización y la posibilidad de que la organización no acepte cambios;
- v) controles de seguridad física acordes con la clasificación de la información;
- w) controles de transferencia de información para proteger la información durante la transferencia física o transmisión lógica;
- x) cláusulas de rescisión al concluir el acuerdo, incluida la gestión de registros, la devolución de activos, la eliminación segura de información y otros activos asociados, y cualquier obligación de confidencialidad en curso;
- y) provisión de un método para destruir de forma segura la información de la organización almacenada por el proveedor tan pronto como ya no sea necesaria;
- z) asegurar, al final del contrato, la entrega del apoyo a otro proveedor o a la propia organización.

La organización debe establecer y mantener un registro de acuerdos con partes externas (por ejemplo, contratos, memorandos de entendimiento, acuerdos de intercambio de información) para realizar un seguimiento de adónde va su información. La organización también debe revisar, validar y actualizar periódicamente sus acuerdos con partes externas para garantizar que sigan siendo necesarios y adecuados para su propósito con las cláusulas de seguridad de la información pertinentes.

Otra información

Los acuerdos pueden variar considerablemente para diferentes organizaciones y entre los diferentes tipos de proveedores. Por lo tanto, se debe tener cuidado de incluir todos los requisitos relevantes para abordar los riesgos de seguridad de la información.

Para obtener detalles sobre acuerdos con proveedores, consulte la serie ISO/IEC 27036. Para los acuerdos de servicios en la nube, consulte la serie ISO/IEC 19086.

5.21 Gestión de la seguridad de la información en la cadena de suministro de las TIC

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Identificar	# relación_proveedor- barcos_seguridad	# Gobernanza_y_ Ecosistema #Protec- ción

Control

Deben definirse e implementarse procesos y procedimientos para gestionar los riesgos de seguridad de la información asociados con la cadena de suministro de productos y servicios de TIC.

Objetivo

Mantener un nivel acordado de seguridad de la información en las relaciones con los proveedores.

Guía

Se deben considerar los siguientes temas para abordar la seguridad de la información dentro de la seguridad de la cadena de suministro de TIC, además de los requisitos generales de seguridad de la información para las relaciones con los proveedores:

- a) definir los requisitos de seguridad de la información que se aplicarán a la adquisición de productos o servicios de TIC;
- b) exigir que los proveedores de servicios de TIC propaguen los requisitos de seguridad de la organización a lo largo de la cadena de suministro si subcontratan partes del servicio de TIC proporcionado a la organización;
- c) exigir que los proveedores de productos TIC propaguen prácticas de seguridad adecuadas a lo largo de la cadena de suministro si estos productos incluyen componentes comprados o adquiridos de otros proveedores u otras entidades (por ejemplo, desarrolladores de software y proveedores de componentes de hardware subcontratados);
- d) solicitar que los proveedores de productos TIC proporcionen información que describa los componentes de software utilizados en los productos;
- e) solicitar que los proveedores de productos TIC proporcionen información que describa las funciones de seguridad implementadas de su producto y la configuración requerida para su operación segura;
- f) implementar un proceso de monitoreo y métodos aceptables para validar que los productos y servicios de TIC entregados cumplan con los requisitos de seguridad establecidos. Los ejemplos de dichos métodos de revisión de proveedores pueden incluir pruebas de penetración y prueba o validación de certificaciones de terceros para las operaciones de seguridad de la información del proveedor;
- g) implementar un proceso para identificar y documentar los componentes del producto o servicio que son críticos para mantener la funcionalidad y, por lo tanto, requieren mayor atención, escrutinio y seguimiento adicional cuando se construyen fuera de la organización, especialmente si el proveedor subcontrata aspectos de los componentes del producto o servicio a otros proveedores;
- h) obtener la seguridad de que los componentes críticos y su origen pueden rastrearse a lo largo de la cadena de suministro;
- i) obtener la seguridad de que los productos TIC entregados funcionan como se espera sin características inesperadas o no deseadas;
- j) implementar procesos para garantizar que los componentes de los proveedores sean genuinos y no se alteren sus especificaciones. Las medidas de ejemplo incluyen etiquetas antimanipulación, verificaciones hash criptográficas o firmas digitales. La supervisión del rendimiento fuera de las especificaciones puede ser un indicador de manipulación o falsificación. La prevención y detección de la manipulación debe implementarse durante varias etapas del ciclo de vida del desarrollo del sistema, incluido el diseño, el desarrollo, la integración, las operaciones y el mantenimiento;
- k) obtener garantías de que los productos TIC alcancen los niveles de seguridad requeridos, por ejemplo, a través de una certificación formal o un esquema de evaluación como el Acuerdo de Reconocimiento de Criterios Comunes;
- l) definir reglas para compartir información sobre la cadena de suministro y cualquier posible problema y compromiso entre la organización y los proveedores;
- m) implementar procesos específicos para gestionar el ciclo de vida y la disponibilidad de los componentes TIC y los riesgos de seguridad asociados. Esto incluye gestionar los riesgos de que los componentes ya no estén disponibles debido a que los proveedores ya no están en el negocio o los proveedores ya no proporcionan estos componentes debido a los avances tecnológicos. Se debe considerar la identificación de un proveedor alternativo y el proceso para transferir el software y la competencia al proveedor alternativo.

Otra información

Las prácticas específicas de gestión de riesgos de la cadena de suministro de TIC se basan en las prácticas generales de seguridad de la información, calidad, gestión de proyectos e ingeniería de sistemas, pero no las reemplazan.

Se aconseja a las organizaciones que trabajen con los proveedores para comprender la cadena de suministro de las TIC y cualquier asunto que tenga un efecto importante en los productos y servicios que se proporcionan. La organización puede influir en las prácticas de seguridad de la información de la cadena de suministro de TIC dejando claro en los acuerdos con sus proveedores los asuntos que deben abordar otros proveedores en la cadena de suministro de TIC.

Las TIC deben adquirirse de fuentes acreditadas. La confiabilidad del software y el hardware es una cuestión de control de calidad. Si bien generalmente no es posible que una organización inspeccione los sistemas de control de calidad de sus proveedores, puede hacer juicios confiables basados en la reputación del proveedor.

La cadena de suministro de TIC, como se aborda aquí, incluye servicios en la nube.

Ejemplos de cadenas de suministro de TIC son:

- a) aprovisionamiento de servicios en la nube, donde el proveedor de servicios en la nube depende de los desarrolladores de software, proveedores de servicios de telecomunicaciones, proveedores de hardware;
- b) IoT, donde el servicio involucra a los fabricantes de dispositivos, los proveedores de servicios en la nube (por ejemplo, los operadores de la plataforma IoT), los desarrolladores de aplicaciones móviles y web, el proveedor de bibliotecas de software;
- c) servicios de hospedaje, donde el proveedor se basa en mesas de servicio externas, incluidos los niveles de soporte primero, segundo y tercero.

Consulte ISO/IEC 27036-3 para obtener más detalles, incluida la guía de evaluación de riesgos.

Las etiquetas de identificación de software (SWID) también pueden ayudar a lograr una mejor seguridad de la información en la cadena de suministro, al proporcionar información sobre la procedencia del software. Ver ISO/IEC 19770-2 para más detalles.

5.22 Seguimiento, revisión y gestión de cambios de servicios de proveedores

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Identificar	# relación_proveedor- barcos_seguridad	# Gobernanza_y_ Ecosistema #Protec- ción # Defensa # Information_secu- rity_assurance

Control

La organización debe monitorear, revisar, evaluar y gestionar periódicamente los cambios en las prácticas de seguridad de la información del proveedor y la prestación de servicios.

Objetivo

Mantener un nivel acordado de seguridad de la información y prestación de servicios en línea con los acuerdos con los proveedores.

Guía

El seguimiento, la revisión y la gestión de cambios de los servicios del proveedor deben garantizar que se cumplan los términos y condiciones de seguridad de la información de los acuerdos, que los incidentes y problemas de seguridad de la información se gestionen adecuadamente y que los cambios en los servicios del proveedor o el estado comercial no afecten la prestación del servicio.

Esto debería implicar un proceso para gestionar la relación entre la organización y el proveedor para:

- a) monitorear los niveles de desempeño del servicio para verificar el cumplimiento de los acuerdos;

b) controlar los cambios realizados por los proveedores, incluidos:

- 1) mejoras a los servicios actuales ofrecidos;
- 2) desarrollo de nuevas aplicaciones y sistemas;
- 3) modificaciones o actualizaciones de las políticas y procedimientos del proveedor;
- 4) controles nuevos o modificados para resolver incidentes de seguridad de la información y mejorar la seguridad de la información;

c) monitorear los cambios en los servicios del proveedor, incluyendo:

- 1) cambios y mejoras a las redes;
- 2) uso de nuevas tecnologías;
- 3) adopción de nuevos productos o versiones o lanzamientos más nuevos;
- 4) nuevas herramientas y entornos de desarrollo;
- 5) cambios en la ubicación física de las instalaciones de servicio;
- 6) cambio de subproveedores;
- 7) subcontratación a otro proveedor;

d) revisar los informes de servicio producidos por el proveedor y organizar reuniones regulares de progreso según lo requieran los acuerdos;

e) realizar auditorías de proveedores y subproveedores, junto con la revisión de los informes de los auditores independientes, si están disponibles, y dar seguimiento a los problemas identificados;

f) proporcionar información sobre incidentes de seguridad de la información y revisar esta información según lo requieran los acuerdos y cualquier guía y procedimiento de apoyo;

g) revisar las pistas de auditoría del proveedor y los registros de eventos de seguridad de la información, problemas operativos, fallas, rastreo de fallas e interrupciones relacionadas con el servicio prestado;

h) responder y gestionar cualquier evento o incidente de seguridad de la información identificado;

i) identificar vulnerabilidades de seguridad de la información y gestionirlas;

j) revisar los aspectos de seguridad de la información de las relaciones del proveedor con sus propios proveedores;

k) asegurar que el proveedor mantenga suficiente capacidad de servicio junto con planes viables diseñados para asegurar que los niveles de continuidad del servicio acordados se mantengan después de fallas importantes en el servicio o desastres (ver [5.29](#), [5.30](#), [5.35](#), [5.36](#), [8.14](#));

l) asegurar que los proveedores asignen responsabilidades para revisar el cumplimiento y hacer cumplir los requisitos de los acuerdos;

m) evaluar periódicamente que los proveedores mantienen niveles adecuados de seguridad de la información.

La responsabilidad de administrar las relaciones con los proveedores debe asignarse a un individuo o equipo designado. Se deben poner a disposición suficientes habilidades técnicas y recursos para monitorear que se cumplan los requisitos del acuerdo, en particular los requisitos de seguridad de la información. Se deben tomar las acciones apropiadas cuando se observen deficiencias en la prestación del servicio.

Otra información

Ver ISO/IEC 27036-3 para más detalles.